



Nhóm 9 Nghiên cứu kỹ thuật Honeypot xây dựng hệ thống bẫy tấn công và phân tích log

An Toàn Và Bảo Mật Thông Tin (Trường Đại học Giao thông Vận tải)



messages.pdf_cover_qr_code_label

TRƯỜNG ĐẠI HỌC GIAO THÔNG VẬN TẢI TP. HỒ CHÍ MINH
VIỆN CÔNG NGHỆ THÔNG TIN VÀ ĐIỆN, ĐIỆN TỬ



BÁO CÁO BÀI TẬP LỚN MÔN
AN TOÀN THÔNG TIN

TÊN ĐỀ TÀI

**NGHIÊN CỨU KỸ THUẬT HONEYPOT: XÂY DỰNG
HỆ THỐNG BẦY TẤN CÔNG VÀ PHÂN TÍCH LOG.**

GVHD: TS. Lê Quốc Tuấn

SVTH:

080305011708_ Huỳnh Thị Hồng Ánh

084305001358_ Huỳnh Thị Thanh Nhi

083305005575_ Nguyễn Thị Bảo Ngọc

Thành phố Hồ Chí Minh, ngày 01 tháng 11 năm 2025

LỜI CẢM ƠN

Kính gửi thầy Lê Quốc Tuấn,

Chúng em xin gửi lời cảm ơn chân thành đến Thầy Lê Quốc Tuấn - người đã tận tình hướng dẫn, chỉ bảo và hỗ trợ em trong suốt quá trình thực hiện đề tài “Nghiên cứu kỹ thuật Honeypot: xây dựng hệ thống bẫy tấn công và phân tích log.”

Trong quá trình nghiên cứu và hoàn thiện báo cáo, Thầy đã giúp chúng em hiểu rõ hơn về các nguyên lý của hệ thống Honeypot, phương pháp triển khai thực tế cũng như cách phân tích log để nhận diện hành vi tấn công. Sự tận tâm và những góp ý quý báu của Thầy đã giúp em hoàn thiện đề tài một cách khoa học và thực tiễn hơn.

Chúng em xin kính chúc thầy luôn dồi dào sức khỏe, nhiều niềm vui và gặt hái được nhiều thành công trong sự nghiệp giảng dạy cao quý này. Mong rằng thầy sẽ mãi là nguồn sáng soi rọi và dẫn lối cho chúng em trên hành trình chinh phục tri thức và cuộc sống.

MỤC LỤC

Chương 1: TỔNG QUAN VỀ KỸ THUẬT HONEYPOT.....	6
1.1 Khái niệm Honeypot.....	6
1.2. Cách thức hoạt động.....	7
1.3. Quy trình hoạt động cơ bản của Honeypot.....	7
1.4. Lợi ích khi sử dụng Honeypot.....	9
1.5. Những rủi ro khi triển khai Honeypot.....	11
CHƯƠNG 2: PHÂN LOẠI HONEYPOT.....	14
2.1 Phân loại theo cấp độ tương tác.....	14
2.1.1. Low-Interaction Honeypots.....	14
2.1.2. Medium-Interaction Honeypots.....	15
2.1.3 High-Interaction Honeypots.....	16
2.1.4 So sánh các loại HoneyPot theo cấp độ tương tác.....	17
2.2. Phân loại theo mục đích sử dụng.....	20
2.2.1 Production Honeypot.....	20
2.2.2 Research Honeypot.....	21
2.2.3 So sánh các loại HoneyPot theo mục đích sử dụng.....	23
2.3 Phân loại HoneyPot theo mối đe dọa.....	23
2.3.1 Spam trap.....	23
2.3.2 Decoy Database HoneyPot.....	24
2.3.3 Malware HoneyPot.....	24
2.3.4 Spider Honeypot.....	25
2.3.5 So sánh các loại HoneyPot theo mối đe dọa.....	25
CHƯƠNG 3: THIẾT KẾ HỆ THỐNG BẦY TẤN CÔNG.....	28
3.1 Mục tiêu thiết kế.....	28
3.2. Yêu cầu hệ thống.....	28
3.2.1. Yêu cầu chức năng.....	28
3.2.2. Yêu cầu phi chức năng.....	29
3.3. Kiến trúc hệ thống.....	29
3.3.1. Tổng quan kiến trúc.....	29
3.3.2. Thành phần và vai trò.....	30

3.3.3. Bảo đảm an toàn kiến trúc.....	30
3.4. Công cụ và công nghệ sử dụng.....	30
3.4.1. VMware Workstation.....	30
3.4.2. Ubuntu Server.....	31
3.4.3. T-Pot.....	31
3.4.4. Kali Linux.....	31
3.4.5. PuTTY.....	31
3.5. Quy trình triển khai hệ thống.....	31
CHƯƠNG 4: THỰC NGHIỆM VÀ PHÂN TÍCH LOG (ANALYSIS).....	44
4.1. Thiết lập môi trường và thực nghiệm.....	44
4.1.1. Cấu hình triển khai Honeypot.....	44
4.1.2. Quy trình tấn công mô phỏng và thu thập dữ liệu.....	45
4.2. Phân tích giao diện giám sát và hoạt động tấn công.....	47
4.2.1. Tổng quan các cuộc tấn công trên dashboard Kibana.....	47
4.2.2. Chi tiết nguồn tấn công, CVE liên quan và chữ ký IDS.....	48
4.2.3. Phân tích payload và tham số tấn công.....	49
4.3 Phân tích log và đánh giá hành vi tấn công.....	49
4.3.1 Phân tích 50 dòng đầu tiên của file <i>auth.log</i>	50
4.3.2. Phân tích 50 dòng cuối của file <i>auth.log</i>	52
CHƯƠNG 5: KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN.....	55
5.1. Kết luận.....	55
5.2. Hạn chế của đề tài.....	55
5.3. Hướng phát triển trong tương lai.....	56
TÀI LIỆU THAM KHẢO.....	58

Danh mục hình ảnh

Hình 4: Giao diện VMware Workstation Pro.....	34
Hình 5: hiển thị màn hình đăng nhập của máy ảo Ubuntu.....	35
Hình 6: Kết quả lệnh ip a trong Ubuntu.....	36
Hình 7: Công cụ PuTTY để truy cập máy chủ Ubuntu.....	37
Hình 8: Chạy lệnh ./install.sh để bắt đầu quá trình cài đặt T-Pot.....	38
Hình 9: Quá trình kéo các Docker image của các honeypot.....	38
Hình 10: kết thúc cài đặt.....	39
Hình 11: Hiển thị màn hình đăng nhập của máy ảo Kali Linux.....	40
Hình 12: Giao diện Desktop của máy ảo Kali Linux, xác nhận việc khởi động thành công.....	40
Hình 13: Cấu hình PuTTY để kết nối SSH tới Host T-Pot sử dụng cổng 64295.....	42
Hình 14: Kết quả lệnh top qua SSH, giám sát tiến trình honeypot.....	43
Hình 15: Đăng nhập vào giao diện web quản trị của T-Pot.....	43
Hình 16: Dashboard Web.....	44
Hình 17: Giao diện Kibana Dashboard (Elastic), dùng để trực quan hóa dữ liệu tấn công.....	44
Hình 18: Giao diện công cụ Cyberchef tích hợp, dùng để phân tích payload.....	45
Hình 19: Giao diện công cụ Spiderfoot tích hợp, dùng để thu thập thông tin tình báo. 45	
Hình 21: Khởi tạo tcpdump để bắt gói trên port 2222. (ubuntu).....	46
Hình 22: Theo dõi auth.log trước khi tấn công.(ubuntu).....	47
Hình 23: Kết nối SSH tới honeypot cổng 2222 (kali).....	47
Hình 24: Kali quét phát hiện SSH trên port 2222. (kali).....	48

Hình 25: Sao chép file log từ honeypot về máy chủ cục bộ qua SCP.....	48
Hình 26: Liệt kê chi tiết (kích thước, quyền, ngày tạo) các file log.....	48
Hình 27: Số các cuộc tấn công trên dashboard Kibana.....	49
Hình 28: Nguồn tấn công.....	50
Hình 29: Phân tích payload tấn công (Wordcloud).....	51
Hình 30: 50 dòng đầu của file auth.log.....	52
Hình 31: Hiển thị 50 dòng cuối của file auth.log.....	54

BẢNG PHÂN CÔNG

STT	Họ và tên	MSSV	Nội dung công việc
1	Huỳnh Thị Hồng Ánh	080305011708	C2: Phân loại honeypot C4: thực nghiệm và phân tích log (analysis), chạy demo
2	Huỳnh Thị Thanh Nhi	084305001358	C3: Thiết kế hệ thống bẫy tấn công Kiểm tra nội dung, chạy demo
3	Nguyễn Thị Bảo Ngọc	083305005575	C1: Tổng quan về kỹ thuật honeypot Làm powerpoint và word

LỜI MỞ ĐẦU

An ninh mạng ngày càng trở thành vấn đề trọng yếu trong bối cảnh chuyển đổi số và phát triển mạnh mẽ của các dịch vụ trực tuyến. Các tổ chức, doanh nghiệp và cá nhân đang phải đối mặt với nhiều loại mối đe dọa tinh vi như tấn công xâm nhập, mã độc, khai thác lỗ hổng và tấn công có chủ đích. Trong khi các giải pháp phòng thủ truyền thống (tường lửa, IDS/IPS, chống mã độc) đóng vai trò quan trọng thì việc chủ động thu thập thông tin về hành vi tấn công và phân tích chiến thuật kẻ xấu lại là bước cần thiết để nâng cao năng lực phòng thủ và phản ứng. Honeypot - một hệ thống giả mạo được thiết kế để thu hút và ghi lại hoạt động tấn công - đang nổi lên như một công cụ nghiên cứu và giám sát mạng hiệu quả.

Đề tài này tập trung nghiên cứu kỹ thuật Honeypot với mục tiêu thiết kế, triển khai một hệ thống bẫy tấn công thực tế và xây dựng quy trình thu thập, xử lý, phân tích log để rút ra thông tin có giá trị về phương thức tấn công, dấu vết kẻ tấn công và các chiến lược khai thác lỗ hổng. Công trình sẽ khảo sát các loại Honeypot (trên mức độ tương tác thấp đến cao), phương pháp cấu hình an toàn, kỹ thuật thu thập sự kiện và lưu trữ log, đồng thời tích hợp các công cụ phân tích tự động nhằm phát hiện mẫu tấn công và hỗ trợ phân loại. Việc kết hợp triển khai thực nghiệm với phân tích dữ liệu log giúp không chỉ đánh giá hiệu quả của hệ thống mà còn cung cấp kiến thức thực tiễn cho công tác phòng thủ chủ động.

Kết quả nghiên cứu kỳ vọng đóng góp vào hai khía cạnh: Cung cấp một mô hình triển khai Honeypot khả thi, an toàn và dễ mở rộng cho môi trường mạng quy mô nhỏ đến trung bình; Phát triển phương pháp phân tích log thực dụng giúp trích xuất các chỉ số và mẫu hành vi tấn công, hỗ trợ cảnh báo sớm và cải thiện chiến lược phòng thủ. Bài báo cáo này sẽ trình bày các bước thiết kế, cài đặt, thu thập dữ liệu, phương pháp phân tích và kết quả thực nghiệm, đồng thời thảo luận các giới hạn và hướng nghiên cứu tiếp theo nhằm hoàn thiện công cụ phòng thủ mạng chủ động.

Chương 1: TỔNG QUAN VỀ KỸ THUẬT HONEYPOT

1.1 Khái niệm Honeypot

Honeypot trong lĩnh vực an toàn mạng, là một hệ thống hoặc tài nguyên được thiết kế đặc biệt để đóng vai trò như một "mồi nhử" nhằm thu hút và ghi nhận các hành vi tấn công từ tin tặc hoặc các thực thể độc hại. Từ "Honeypot" (nồi mật ong) bắt nguồn từ ý tưởng rằng nó giống như một cái bẫy ngọt ngào, lôi kéo kẻ tấn công tương tự cách mật ong thu hút côn trùng. Trong thực tế, Honeypot không phải là một hệ thống sản xuất thực sự phục vụ người dùng cuối, mà là một công cụ giám sát được triển khai với mục đích phát hiện, phân tích và học hỏi từ các mối đe dọa mạng.

Vai trò của Honeypot trong an toàn mạng là vô cùng quan trọng. Trước hết, nó hoạt động như một hệ thống cảnh báo sớm, giúp các quản trị viên mạng nhận biết sự hiện diện của các cuộc tấn công mà không ảnh hưởng đến các hệ thống chính thức. Ví dụ, nếu một kẻ tấn công cố gắng khai thác một lỗ hổng trong dịch vụ SSH (Secure Shell) trên Honeypot, thông tin này sẽ được ghi lại mà không gây nguy hiểm cho máy chủ thực sự. Thứ hai, Honeypot đóng vai trò như một công cụ thu thập thông tin tình báo mạng (cyber threat intelligence), cung cấp dữ liệu chi tiết về chiến thuật, kỹ thuật và quy trình (TTP - Tactics, Techniques, and Procedures) mà kẻ tấn công sử dụng. Cuối cùng, Honeypot hỗ trợ cải thiện các biện pháp bảo mật bằng cách cung cấp dữ liệu thực tế để thử nghiệm và nâng cấp các hệ thống phòng thủ như IDS (Intrusion Detection System) hay tường lửa (firewall).

Một điểm đáng chú ý là Honeypot không phải là giải pháp thay thế cho các công cụ bảo mật truyền thống như tường lửa hay phần mềm diệt virus, mà là một phần bổ sung trong chiến lược bảo mật toàn diện. Nó có thể được triển khai trong nhiều môi trường khác nhau, từ mạng nội bộ của doanh nghiệp nhỏ đến các hệ thống nghiên cứu quy mô lớn của các tổ chức an ninh mạng. Sự linh hoạt và khả năng tùy chỉnh của Honeypot

khiến nó trở thành một công cụ không thể thiếu trong bối cảnh các cuộc tấn công mạng ngày càng tinh vi.

1.2. Cách thức hoạt động

Honeypot hoạt động như một hệ thống máy tính ngoài đời thực, honeypot có các ứng dụng và dữ liệu để đánh lừa tội phạm, làm chúng nghĩ rằng đây là một mục tiêu mà chúng có thể nhắm tới.

Ví dụ, honeypot có thể giả làm một hệ thống thanh toán dành cho khách hàng của công ty và mục tiêu tấn công của các kẻ tấn công là thu thập các mã số thẻ tín dụng. Một khi kẻ tấn công xâm nhập vào, chúng có thể bị theo dõi, và các hành vi của chúng được đánh giá, từ đó có thể xây dựng hệ thống an toàn hơn chống lại các hành động đó.

Một yếu tố quan trọng của honeypot đó chính là hệ thống này được tạo ra với các lỗ hổng bảo mật thêm vào có chủ đích. Ví dụ, hệ thống honeypot có thể mở các cổng để phản hồi với việc các kẻ tấn công quét cổng hệ thống và dò quét mật khẩu yếu. Các cổng dễ bị tấn công có thể được mở để dụ các kẻ tấn công đi vào môi trường của honeypot

1.3. Quy trình hoạt động cơ bản của Honeypot

Mặc dù có nhiều loại Honeypot với mức độ tương tác và mục tiêu khác nhau nhưng nhìn chung, chúng đều hoạt động theo một quy trình cơ bản gồm các giai đoạn sau:

Bước 1: Triển khai và thu hút tấn công:

Ở giai đoạn đầu, honeypot được triển khai trong mạng và được cấu hình sao cho trông giống như một hệ thống thật, nhằm đánh lừa kẻ tấn công. Khi phát hiện mục tiêu này, kẻ tấn công bắt đầu tiến hành các hoạt động thăm dò như quét cổng, nhận dạng hệ điều hành, khai thác lỗ hổng dịch vụ, hoặc tấn công brute-force (đặc biệt là trên giao thức SSH). Trong quá trình này, honeypot sẽ ghi nhận các thông tin ban đầu bao gồm thời gian, địa chỉ IP nguồn, cổng bị tấn công và phương pháp khai thác được sử dụng.

Bước 2: Quan sát và ghi nhận hành vi:

Khi kẻ tấn công đã xâm nhập thành công, honeypot sẽ tiếp tục giám sát và ghi lại toàn bộ hành vi trong hệ thống. Các dữ liệu được thu thập bao gồm chuỗi lệnh được thực thi, các tập tin được tạo, chỉnh sửa hoặc xóa, các tiến trình mạng được kích hoạt, cũng như mọi hoạt động đáng ngờ khác. Việc ghi nhận này diễn ra trong môi trường cô lập, giúp phân tích hành vi tấn công mà không ảnh hưởng đến hệ thống thật.

Bước 3: Thu thập và xử lý thông tin tình báo:

Toàn bộ các tương tác và hành vi của kẻ tấn công được lưu trữ để phục vụ cho quá trình phân tích tình báo an ninh. Với các Honeypot có mức độ tương tác cao (High-Interaction Honeypot), hệ thống có thể ghi lại toàn bộ phiên làm việc hoặc chụp ảnh trạng thái nhằm tái hiện chi tiết quá trình tấn công.

Bước 4: Phân tích dữ liệu:

Dữ liệu thu thập được sẽ được xử lý và phân tích để xác định loại hình tấn công và các mối đe dọa tiềm ẩn. Quá trình này bao gồm việc so sánh với các mẫu tấn công đã biết, phát hiện hành vi bất thường, và trích xuất thông tin quan trọng như địa chỉ IP, tên miền, hoặc chuỗi lệnh nghi ngờ. Kết quả phân tích cung cấp cơ sở dữ liệu quan trọng cho việc phát hiện và phòng ngừa tấn công trong tương lai.

Bước 5: Cải thiện và phản ứng an ninh:

Dựa trên các phát hiện thu được, hệ thống an ninh thực có thể được nâng cấp và tối ưu hóa. Honeypot có thể tự động gửi cảnh báo cho quản trị viên khi phát hiện hành vi bất thường, đồng thời thực hiện các biện pháp phản ứng như chặn địa chỉ IP tấn công trên tường lửa, cập nhật danh sách đen, bổ sung chữ ký tấn công cho các hệ thống IDS/IPS như Suricata hoặc Snort, và điều chỉnh chính sách bảo mật nội bộ. Nhờ đó, tổ chức có thể cải thiện khả năng phát hiện sớm, giảm thiểu rủi ro và tăng cường khả năng phòng vệ tổng thể của hệ thống mạng.

Bằng cách giám sát lưu lượng dữ liệu trong hệ thống HoneyPot, người quản lý có thể nắm bắt được những thông tin như:

- Kẻ tấn công đến từ đâu?
- Mức độ nguy hiểm của mối đe dọa như thế nào?
- Hệ thống chúng sử dụng để tấn công là gì?
- Chúng thường nhắm tới nguồn dữ liệu nào?
- Hệ thống của mình có đủ tốt để ngăn chặn những cuộc tấn công hay chưa?

1.4. Lợi ích khi sử dụng Honeypot

HoneyPot đem lại rất nhiều lợi ích trong việc nâng cao khả năng bảo vệ và phát hiện mối đe dọa, giúp tổ chức chủ động hơn trong môi trường an ninh mạng ngày càng phức tạp. Cụ thể:

- Phát hiện sớm mối đe dọa:
 - Honeypot cho phép người quản trị mạng phát hiện sớm các mối đe dọa và tấn công mạng, thậm chí cả những mối đe dọa mới (zero-day attacks) mà không thể được phát hiện bằng các phương pháp bảo mật truyền thống như IDS/IPS.
 - Hoạt động như bẫy giả lập, thu hút kẻ tấn công và ghi nhận hành vi chi tiết mà không ảnh hưởng đến hệ thống sản xuất thực tế, cho phép giám sát liên tục các mối đe dọa mới nổi, tăng cường tổng thể hệ thống giám sát.
 - Honeypot toàn cầu ghi nhận trung bình 500.000 tấn công/ngày, cung cấp dữ liệu cho AI/ML dự đoán tấn công, giúp ứng dụng kiến thức an ninh mạng lớn và cập nhật tiện ích bảo toàn nguồn mạng, tiết kiệm chi phí phản ứng lên đến 20-30%.

- Thu thập thông tin và phân tích:
 - Honeypot cung cấp dữ liệu chi tiết về các kỹ thuật tấn công, công cụ và phương pháp sử dụng bởi kẻ tấn công (TTPs - tactics, techniques, procedures), đây là những yếu tố quan trọng giúp nhà quản trị nâng cao cảnh báo và phản ứng thông minh trước mỗi đe dọa.
 - Không xử lý lưu lượng hợp pháp, nên mọi hoạt động đều đáng ngờ, giảm false positives (tỷ lệ cảnh báo sai thấp xuống gần 0%), giúp đội ngũ tập trung nguồn lực.
 - Honeypot cung cấp dữ liệu và thông tin hữu ích để nghiên cứu về các mối đe dọa, làm nền tảng chia sẻ thông tin và hợp tác trong cộng đồng an ninh mạng, đồng thời hỗ trợ forensics để cải thiện chiến lược dài hạn.
- Bảo vệ hệ thống thực tế:
 - Bằng cách mô phỏng một mục tiêu giả mạo, Honeypot sẽ hạn chế tác động của tấn công vào hệ thống thực tế, giữ cho cơ sở hạ tầng mạng của tổ chức an toàn, đồng thời phân tán sự chú ý của kẻ tấn công (distraction).
 - Có thể triển khai bên trong mạng nội bộ để phát hiện insider threats (mối đe dọa nội bộ), bổ sung kiểm soát truy cập truyền thống.
 - Honeypot cung cấp dữ liệu và thông tin hữu ích để nghiên cứu về các mối đe dọa, hỗ trợ bảo vệ hệ thống thật bằng cách làm phân tâm hacker và giảm áp lực tấn công trực tiếp.
- Tăng cường phòng ngừa:
 - Quá trình sử dụng Honeypot sẽ làm giảm khả năng bị tấn công mạng thực sự, tạo ra áp lực và rà soát kỹ thuật tấn công đối với kẻ tấn công,

cung cấp dữ liệu thực tế cho việc phân tích và kiểm tra hiệu quả của chiến lược bảo mật.

- Giúp cải thiện và phát triển chiến lược bảo mật mạng tổng thể, kết hợp với deception technology (công nghệ lừa đảo) để mang lại lợi ích hybrid, đặc biệt hữu ích cho tổ chức Việt Nam ứng phó với tấn công APT (advanced persistent threats) từ nguồn ngoại.
- Nền tảng cung cấp dữ liệu thực tế để nâng cao phòng ngừa, giảm khả năng bị khai thác lỗ hổng và tăng cường khả năng phản ứng chủ động.

Như vậy, honeypot không chỉ tăng cường phòng ngừa mà còn cung cấp dữ liệu quý giá để cải thiện chiến lược bảo mật dài hạn, giúp tổ chức chủ động hơn trong môi trường mạng phức tạp.

1.5. Những rủi ro khi triển khai Honeypot

Mặc dù mang lại lợi ích, HoneyPot cũng tồn tại nhiều rủi ro tiềm ẩn nếu không được quản lý đúng cách, có thể dẫn đến hậu quả nghiêm trọng hơn dự kiến. Các rủi ro chính bao gồm:

- Tăng cường mục tiêu:
 - Một Honeypot có thể trở thành một mục tiêu cho các kẻ tấn công chuyên nghiệp, đặt ra nguy cơ tác động đến cơ sở hạ tầng mạng thực tế của tổ chức nếu bị khai thác để "thoát ra" (breakout risk).
 - Kẻ tấn công tinh vi có thể sử dụng honeypot làm bàn đạp tấn công hệ thống khác nếu không cách ly tốt, dẫn đến lan rộng tấn công và thiệt hại lớn.
 - Honeypot high-interaction (tương tác cao) từng bị breakout do misconfiguration (cấu hình sai); rủi ro nhận diện qua dấu vân tay hệ

thống khiến hacker tránh bẫy hoặc lợi dụng tấn công ngược, tăng bề mặt tấn công tổng thể.

- Gây ra sự hiểu lầm:
 - Trong một số trường hợp, Honeypot có thể tạo ra sự hiểu lầm về các hoạt động mạng đáng nghi và gây ra sự nguy cơ báo động không chính xác (false positives gián tiếp hoặc nhiễu dữ liệu).
 - Honeypot chỉ bổ sung, không thay thế firewall/IDS, dẫn đến bỏ lỡ mối đe dọa không nhắm bẫy (limited visibility - tầm nhìn hạn chế), gây hiểu nhầm trong phân tích log hoặc lãng phí nguồn lực phản ứng.
 - Dữ liệu thu thập có giá trị hạn chế nếu không phân tích sâu, dẫn đến hiểu lầm về mức độ đe dọa thực sự trong hệ thống.
- Tăng chi phí:
 - Triển khai và duy trì Honeypot yêu cầu kỹ thuật và tài chính đáng kể, từ việc cấu hình đến việc giám sát và phản ứng với các tấn công .
 - Đòi hỏi tài nguyên chuyên môn cao , chi phí bảo trì định kỳ (patch management - vá lỗ hổng), và có thể tăng ngân sách tổng thể bảo mật lên 15-20% nếu triển khai quy mô lớn.
- Bảo mật thông tin:
 - Nếu không được cấu hình và quản lý đúng cách, thông tin trong Honeypot (dù giả) có thể trở thành mục tiêu cho kẻ tấn công, gây ra rủi ro cho thông tin quan trọng của tổ chức .
 - Có nguy cơ vi phạm pháp lý nếu log chứa dữ liệu thực (IP, bait data - dữ liệu mồi nhử) bị lộ, vi phạm Nghị định 13/2023/NĐ-CP về bảo vệ dữ liệu cá nhân hoặc GDPR ở môi trường quốc tế.

- Honeypot có thể bị khai thác để social engineering (kỹ thuật xã hội) hoặc rò rỉ insights về hệ thống thật nếu không anonymize (ẩn danh) dữ liệu đúng cách.
- Tiêu tốn tài nguyên mạng:
 - Honeypot có thể tiêu tốn tài nguyên mạng quý báu, đặc biệt là khi được triển khai trên quy mô lớn (bandwidth - băng thông, CPU, storage cho log).
 - Trong môi trường IoT/5G, có thể gây quá tải nếu bị DDoS nhắm vào bẫy, ảnh hưởng gián tiếp đến mạng nội bộ nếu không cách ly hoàn toàn.
 - Honeypot lớn có thể tiêu hao đến 10-20% tài nguyên server, đòi hỏi tối ưu hóa để tránh làm suy yếu hệ thống chính.

Để tận dụng tối đa honeypot, tổ chức nên thực hiện phân tích rủi ro và triển khai trong môi trường kiểm soát, đảm bảo không làm suy yếu hệ thống bảo mật hiện tại.

CHƯƠNG 2: PHÂN LOẠI HONEYPOT

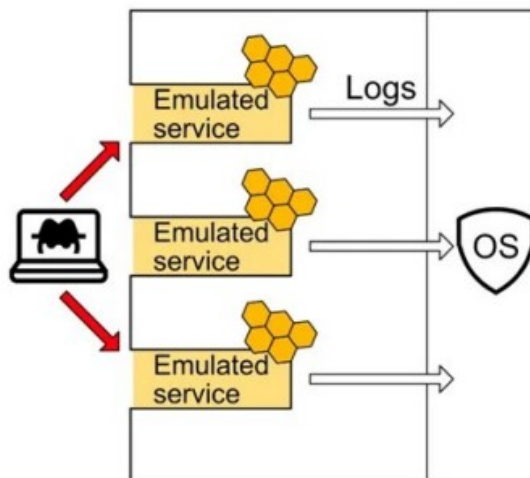
2.1 Phân loại theo cấp độ tương tác

Honeypot thường được phân loại theo mức độ tương tác mà nó cho phép “kẻ tấn công” thực hiện - từ đơn giản (ít tương tác) đến phức tạp (tương tác cao). Ba mức phổ biến là: Thấp (Low-Interaction), Trung bình (Medium-Interaction), cao (High-Interaction).

2.1.1. Low-Interaction Honeypots

Low-Interaction Honeypots (Honeypot tương tác thấp) là loại bẫy tấn công có mức độ tương tác thấp nhất với kẻ tấn công. Loại này chỉ mô phỏng một phần nhỏ các dịch vụ hoặc giao thức mạng cơ bản như HTTP, FTP, SSH,... mà không cung cấp quyền truy cập thực vào hệ điều hành hay tài nguyên của hệ thống.

Mục tiêu của loại honeypot này là ghi nhận và phát hiện các hoạt động quét cổng, thử đăng nhập hoặc các hành vi khai thác sơ bộ từ kẻ tấn công. Low-Interaction Honeypot thường chỉ phản hồi ở mức bề mặt và không cho phép thực hiện bất kỳ thao tác nào sâu hơn trong hệ thống.



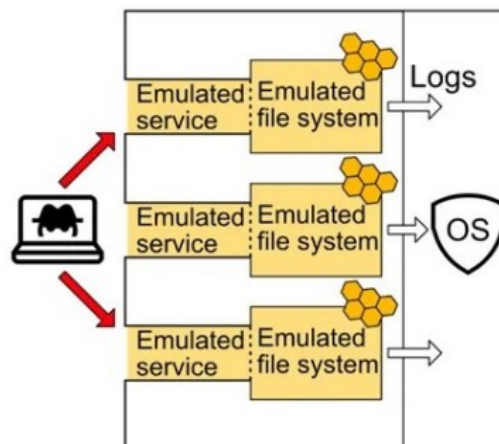
Hình 1: Low-Interaction Honeypots

Hình trên mô tả mô hình Honeypot tương tác thấp, trong đó các dịch vụ mô phỏng được triển khai để đánh lừa kẻ tấn công rằng chúng là thật. Hệ thống chỉ phản hồi ở mức cơ bản và ghi lại log hành vi tấn công, trong khi hệ điều hành thật không bị truy cập trực tiếp, giúp giảm thiểu rủi ro và chủ yếu phục vụ mục đích phát hiện, ghi nhận các hoạt động quét hoặc tấn công ban đầu.

2.1.2. Medium-Interaction Honeypots

Medium-Interaction Honeypots (Honeypot tương tác trung bình) có khả năng tương tác với kẻ tấn công ở mức độ cao hơn so với loại Low-Interaction. Hệ thống này mô phỏng chi tiết hơn các ứng dụng hoặc dịch vụ, cho phép kẻ tấn công gửi các lệnh và nhận phản hồi gần giống như trên hệ thống thật, nhưng vẫn trong phạm vi mô phỏng, không có hệ điều hành thật.

Loại honeypot này thường được thiết kế để ghi nhận thêm các hành vi tấn công ở giai đoạn khai thác ứng dụng hoặc xâm nhập hệ thống. Mục tiêu chính của Medium-Interaction Honeypot là thu thập thêm thông tin về kỹ thuật tấn công mà vẫn đảm bảo mức độ an toàn nhất định cho hệ thống thật.



Hình 2: Medium-Interaction Honeypots

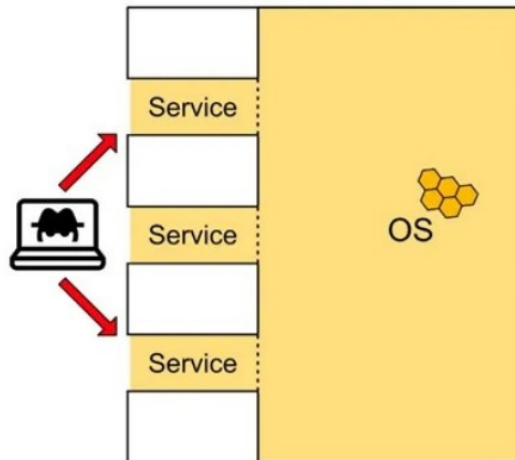
Trong mô hình này, các dịch vụ mô phỏng không chỉ phản hồi cơ bản mà còn được bổ sung hệ thống tệp mô phỏng, giúp giả lập môi trường hệ thống thật ở mức sâu hơn. Điều này cho phép kẻ tấn công tương tác nhiều hơn, thực hiện các thao tác như đọc ghi dữ liệu hoặc thử khai thác lỗi, trong khi hệ thống vẫn giới hạn quyền truy cập vào hệ điều hành thật.

Các hoạt động của kẻ tấn công được ghi lại chi tiết hơn trong log, phục vụ phân tích hành vi và kỹ thuật tấn công, đồng thời vẫn đảm bảo an toàn cho máy chủ thật nhờ lớp mô phỏng trung gian.

2.1.3 High-Interaction Honeypots

High-Interaction Honeypot (Honeypot tương tác cao) là loại có mức độ tương tác cao nhất, cung cấp cho kẻ tấn công một môi trường gần giống hoàn toàn với hệ thống thật. Honeypot này cho phép truy cập vào hệ điều hành thật, có thể chạy nhiều dịch vụ thật và cho phép kẻ tấn công thực hiện đầy đủ các thao tác như khai thác, leo thang đặc quyền, cài đặt mã độc hoặc chiếm quyền điều khiển hệ thống.

Loại honeypot này thường được triển khai trong các môi trường nghiên cứu để quan sát, phân tích hành vi và chiến thuật tấn công thực tế của đối tượng xâm nhập. Việc triển khai High-Interaction Honeypot đòi hỏi phải có cơ chế cách ly, giám sát và quản lý nghiêm ngặt để tránh gây ảnh hưởng đến hệ thống thật.



Hình 3: High-Interaction Honeypots

Trong mô hình này, các dịch vụ là dịch vụ thật chạy trên một hệ điều hành thật đầy đủ, cung cấp môi trường hệ thống ở mức độ sâu nhất. Hệ thống không giới hạn tương tác, mà cho phép kẻ tấn công thực hiện toàn bộ các hành vi như xâm nhập, chạy lệnh, leo quyền, và cài đặt mã độc như trên một máy chủ thực.

Việc cung cấp môi trường thật cho phép kẻ tấn công tương tác cực kỳ sâu, thực hiện các thao tác từ đọc, ghi dữ liệu đến khai thác lỗ hổng. Hệ thống cho phép quyền truy cập đầy đủ vào hệ điều hành thông qua các giao diện mạng chuẩn.

Các hoạt động của kẻ tấn công được ghi lại với mức độ chi tiết cao nhất (bao gồm session recording, network capture, và log), phục vụ phân tích chuyên sâu về chiến thuật tấn công hậu-khai thác. Tuy nhiên, để đảm bảo an toàn, mô hình này yêu cầu cơ chế cách ly vật lý hoặc ảo hóa nghiêm ngặt (công nghệ ảo hóa/phân đoạn mạng) thay vì mô phỏng.

2.1.4 So sánh các loại HoneyPot theo cấp độ tương tác

Tiêu chí	Low-Interaction Honeypots	Medium-Interaction Honeypots	High-Interaction Honeypots
Mô tả	Chỉ mô phỏng một số dịch vụ cơ bản, không có hệ điều hành thật sự, chủ yếu để đánh lừa các bot, scan tự động.	Mô phỏng nhiều dịch vụ hơn, có khả năng phản hồi tương tác cơ bản, cho phép quan sát hành vi tấn công nhưng vẫn an toàn.	Cho phép kẻ tấn công tương tác gần như thật với hệ điều hành và dịch vụ thực, thu thập thông tin chi tiết về các kỹ thuật tấn công tinh vi.
Ưu điểm	- Triển khai nhanh, dễ cấu hình và quản lý. - Rủi ro ảnh hưởng đến hệ thống thật rất thấp. - Tốn ít tài nguyên phần cứng và phần mềm.	- Thu thập thông tin chi tiết hơn so với honeypot thấp. - Vẫn giữ an toàn cho hạ tầng thật nếu được quản lý tốt. - Phù hợp để phân tích hành vi malware.	- Thu thập dữ liệu đầy đủ và chi tiết nhất, bao gồm các kỹ thuật tấn công tinh vi, zero-day, hay các exploit nâng cao. - Phát hiện được các cuộc tấn công chưa từng thấy.
Nhược điểm	- Không phát hiện được các tấn công phức tạp, các kỹ	- Cần quản lý cẩn thận, có thể bị khai thác lỗ hổng giả lập	- Rủi ro bảo mật cao, nếu kẻ tấn công thoát ra ngoài hệ thống

	thuật zero-day. - Thông tin thu thập hạn chế, chủ yếu chỉ biết có tấn công.	nếu không kiểm soát tốt. - Yêu cầu nhiều tài nguyên hơn so với honeypot thấp.	honeypot, có thể gây hại cho hạ tầng thật. - Triển khai phức tạp, tốn nhiều tài nguyên và yêu cầu giám sát liên tục.
Đối tượng nên sử dụng	Tổ chức nhỏ, lab học tập, hoặc đội an ninh muốn phát hiện scan/botnet cơ bản; ngân sách và nguồn lực hạn chế.	Nhóm phân tích malware trung bình muốn phân tích tấn công thực tế nhưng vẫn giữ an toàn.	Các tổ chức nghiên cứu, đội phản ứng sự cố chuyên sâu, lab forensic; có khả năng cô lập hạ tầng và giám sát 24/7.
Rủi ro bảo mật	Rủi ro thấp, vì kẻ tấn công không thể truy cập hệ thống thật.	Rủi ro trung bình, vì kẻ tấn công có thể khai thác lỗ hổng giả lập nếu không quản lý cẩn thận.	Rủi ro cao, vì kẻ tấn công có thể thao túng hệ thống honeypot nếu cấu hình sai hoặc không giám sát chặt.

Mức độ thu thập thông tin	Hạn chế, chỉ biết kiểu tấn công, địa chỉ IP, loại scan, malware cơ bản.	Trung bình, thu thập được hành vi tấn công, loại exploit, payload cơ bản và tương tác với hệ thống.	Cao, thu thập chi tiết các bước tấn công, payload phức tạp, kỹ thuật khai thác nâng cao, log hệ thống và các tương tác tinh vi.
Khả năng tương tác với kẻ tấn công	Hạn chế, chỉ phản hồi cơ bản, gần như không có tương tác thực.	Trung bình, phản hồi được nhiều hành vi tấn công nhưng chưa hoàn toàn giống hệ thống thật.	Cao, cho phép kẻ tấn công thao tác gần như trên hệ thống thật, tương tác toàn diện.

2.2. Phân loại theo mục đích sử dụng.

Honeypot không chỉ được phân loại dựa trên mức độ tương tác mà còn dựa trên mục đích sử dụng chính. Theo tiêu chí này, honeypot thường được chia thành Production Honeypot và Research Honeypot.

Việc phân loại theo mục đích sử dụng giúp các tổ chức lựa chọn loại honeypot phù hợp với nhu cầu bảo mật và năng lực quản lý của mình, đồng thời cân bằng giữa mức độ thu thập thông tin và rủi ro bảo mật.

2.2.1 Production Honeypot

Production Honeypot là loại honeypot được triển khai trong môi trường mạng sản xuất thực tế của tổ chức, nhằm giám sát, phát hiện và phòng ngừa các cuộc tấn công thật

nhắm vào hệ thống. Chúng hoạt động như một “cảm biến” bảo mật, cung cấp thông tin cảnh báo sớm mà không làm gián đoạn các dịch vụ chính.

Đặc điểm:

- Triển khai gần hoặc trong môi trường sản xuất.
- Mức độ tương tác thường thấp đến trung bình để giảm rủi ro cho hệ thống thật.
- Dễ quản lý và duy trì, ít tốn tài nguyên.
- Thường chỉ giả lập một số dịch vụ phổ biến để lừa kẻ tấn công.

Chức năng:

- Phát hiện các cuộc tấn công, scan và probe tự động.
- Ghi lại thông tin cơ bản về kẻ tấn công, như địa chỉ IP, loại tấn công, cổng bị quét.
- Cảnh báo sớm cho đội bảo mật về các nguy cơ tiềm ẩn.
- Hỗ trợ trong việc cải thiện các biện pháp bảo mật mạng và firewall.

Hạn chế:

- Thông tin thu thập hạn chế, không cung cấp dữ liệu chi tiết về kỹ thuật tấn công phức tạp.
- Dễ bị nhận diện là honeypot nếu attacker kiểm tra kỹ.
- Không thích hợp để phân tích malware tinh vi hoặc nghiên cứu kỹ thuật tấn công nâng cao.

2.2.2 Research Honeypot

Research Honeypot là loại honeypot được triển khai chủ yếu cho mục đích nghiên cứu và phân tích hành vi tấn công, malware hoặc các kỹ thuật xâm nhập. Chúng giúp các

nhà nghiên cứu và chuyên gia an ninh mạng thu thập dữ liệu chi tiết để nâng cao kiến thức, cải thiện phòng thủ, và phát hiện các lỗ hổng chưa biết (zero-day).

Đặc điểm:

- Thường triển khai trong môi trường cô lập hoặc lab chuyên dụng, không trực tiếp liên quan đến hệ thống sản xuất.
- Mức độ tương tác trung bình đến cao, cho phép kẻ tấn công thao tác gần như trên hệ thống thật.
- Cấu hình phức tạp, yêu cầu giám sát và logging liên tục.
- Hỗ trợ phân tích chi tiết về các kỹ thuật khai thác, malware, và hành vi tấn công.

Chức năng:

- Thu thập thông tin chi tiết về hành vi hacker và malware.
- Phân tích kỹ thuật khai thác, payload, và các bước post-exploitation.
- Hỗ trợ nghiên cứu nâng cao về an ninh mạng, forensic, và phát triển các cơ chế phòng thủ mới.
- Kiểm thử các kỹ thuật tấn công trong môi trường an toàn để đưa ra giải pháp phòng ngừa.

Hạn chế :

- Rủi ro bảo mật cao nếu không được cô lập hoặc giám sát chặt chẽ.
- Triển khai phức tạp, tốn nhiều tài nguyên (CPU, RAM, storage).
- Không phù hợp để triển khai trực tiếp trong môi trường sản xuất vì có thể bị attacker khai thác.
- Quản lý và vận hành đòi hỏi đội ngũ chuyên môn cao.

2.2.3 So sánh các loại HoneyPot theo mục đích sử dụng

Tiêu chí	Production Honeypot	Research Honeypot
Mục đích	Phát hiện và phòng ngừa các cuộc tấn công thực tế nhắm vào hệ thống sản xuất.	Nghiên cứu, phân tích hành vi tấn công, malware và kỹ thuật xâm nhập.
Phạm vi triển khai	Môi trường sản xuất thực tế hoặc gần thực tế.	Môi trường lab hoặc cô lập, không trực tiếp liên quan đến hệ thống sản xuất.
Mức độ tương tác với kẻ tấn công	Thấp đến trung bình, phản hồi hạn chế để giảm rủi ro.	Trung bình đến cao, cho phép attacker thao tác gần như thật trên hệ thống.
Tính an toàn và rủi ro	An toàn cao, rủi ro thấp cho hệ thống thật.	Rủi ro cao nếu cô lập không tốt; cần giám sát và containment chặt chẽ.
Khả năng phân tích và thu thập thông tin	Hạn chế: chỉ ghi nhận kiểu tấn công, IP, vài payload cơ bản.	Cao: ghi lại toàn bộ hoạt động, payload, kỹ thuật khai thác và hành vi attacker.
Đối tượng sử dụng	Tổ chức cần giám sát hệ thống thực, phát hiện scan/botnet cơ bản, ngân sách và nguồn lực hạn chế.	Các tổ chức nghiên cứu, phòng lab forensic, đội phản ứng sự cố chuyên sâu, cần phân tích kỹ thuật tấn công nâng cao.

2.3 Phân loại HoneyPot theo mối đe dọa

Ngoài việc phân loại theo mức độ tương tác hay mục đích sử dụng, Honeypot còn có thể được phân loại dựa trên loại mối đe dọa mà chúng nhắm tới. Việc này giúp tổ chức thiết kế Honeypot phù hợp với loại tấn công cụ thể và thu thập dữ liệu chính xác, phục vụ cho phòng ngừa, phân tích và nghiên cứu.

2.3.1 Spam trap

Spam Trap Honeypot là loại honeypot được thiết kế để phát hiện và thu thập các email rác (spam), bot gửi thư hoặc các cuộc tấn công liên quan đến email. Chúng thường là các địa chỉ email giả hoặc mail server được công khai nhưng không sử dụng thực tế. Mục tiêu chính của Spam Trap là ngăn chặn spam, phân tích nguồn gốc, kỹ thuật gửi spam và hành vi của spammer.

Spam Trap thường thu thập thông tin về IP gửi thư, nội dung email, kỹ thuật gửi, loại malware đính kèm (nếu có). Các dữ liệu này giúp các tổ chức xây dựng danh sách đen hoặc cải thiện các bộ lọc spam. Loại honeypot này rất ít rủi ro cho hệ thống thật, vì email giả không liên quan đến dữ liệu hoặc người dùng thực.

2.3.2 Decoy Database HoneyPot

Decoy Database Honeypot là một cơ sở dữ liệu giả được triển khai để thu hút các cuộc tấn công nhắm vào database, như SQL Injection, brute-force hoặc khai thác lỗ hổng dịch vụ cơ sở dữ liệu. Mục tiêu của loại honeypot này là phát hiện và nghiên cứu các kỹ thuật tấn công vào dữ liệu quan trọng mà không làm ảnh hưởng đến hệ thống thật.

Honeypot này chứa dữ liệu giả, nhưng được trình bày giống dữ liệu thật để lừa kẻ tấn công. Khi attacker cố gắng khai thác, hệ thống ghi lại các truy vấn SQL, payload, cách tấn công, địa chỉ IP và thời gian tấn công. Thông tin này giúp nhóm bảo mật nghiên cứu hành vi tấn công, vá lỗ hổng, và thiết kế biện pháp phòng ngừa hiệu quả.

2.3.3 Malware HoneyPot

Malware Honeypot là loại honeypot được thiết kế để thu hút và phân tích phần mềm độc hại (malware), trojan, worm, hoặc các cuộc tấn công tự động nhắm vào hệ thống. Mục tiêu chính là thu thập mẫu malware, nghiên cứu hành vi lây lan, cách malware khai thác hệ thống và tương tác với các dịch vụ.

Malware Honeypot thường mô phỏng hệ điều hành hoặc ứng dụng dễ bị tấn công. Khi malware thực thi, honeypot ghi lại hoạt động của malware, các file được tạo, registry thay đổi, kết nối mạng, và các kỹ thuật khai thác. Dữ liệu này hỗ trợ các nhóm nghiên cứu phân tích, xây dựng signature, và cải thiện hệ thống phát hiện malware.

2.3.4 Spider Honeypot

Spider Honeypot là một dạng honeypot chuyên biệt dành cho web, được thiết kế để phát hiện, thu thập thông tin và chặn các trình thu thập dữ liệu tự động (webcrawler, spider hoặc bot). Mục tiêu chính của Spider Honeypot là bảo vệ các trang web khỏi các loại bot độc hại hoặc không mong muốn, đồng thời cung cấp dữ liệu để phân tích hành vi của các bot này.

Spider Honeypot tạo ra các trang web hoặc liên kết đặc biệt, chỉ các bot hoặc spider mới có thể truy cập, trong khi người dùng bình thường khó nhìn thấy hoặc truy cập. Khi bot tương tác với các liên kết này, hệ thống ghi lại IP, hành vi truy cập, đường dẫn truy cập và các kỹ thuật bỏ qua hạn chế. Thông tin này giúp tổ chức phân tích botnet, tối ưu hóa firewall và các biện pháp bảo vệ web hiệu quả hơn.

2.3.5 So sánh các loại HoneyPot theo mối đe dọa

Tiêu chí	Spam Trap Honeypot	Decoy Database Honeypot	Malware Honeypot	Spider Honeypot
-----------------	---------------------------	--------------------------------	-------------------------	------------------------

Mục tiêu	Phát hiện và phân tích email rác (spam) và bot gửi thư.	Phát hiện và nghiên cứu các cuộc tấn công vào cơ sở dữ liệu (SQLi, brute-force...).	Thu hút và phân tích phần mềm độc hại (malware, trojan, worm).	Phát hiện, thu thập thông tin và chặn bot, webcrawler, spider độc hại.
Cách hoạt động	Dùng địa chỉ email giả hoặc mail server công khai làm “bẫy”.	Tạo cơ sở dữ liệu giả chứa dữ liệu giống thật để lừa attacker khai thác.	Mô phỏng OS/ứng dụng để bị tấn công để malware thực thi và bị ghi nhật ký.	Tạo trang/URL “bẫy” chỉ bot mới truy cập, người dùng thực khó thấy.
Dữ liệu thu thập	IP gửi, nội dung email, kỹ thuật gửi, file đính kèm độc hại.	Truy vấn SQL, payload, IP, thời điểm, chuỗi tấn công.	Hoạt động malware, file/registry thay đổi, kết nối mạng, kỹ thuật khai thác.	IP bot, đường dẫn truy cập, tần suất/tốc độ truy vấn, pattern bot.
Đối tượng sử dụng	Bộ phận bảo mật email, ISP, tổ chức muốn cải thiện bộ lọc spam.	Nhóm bảo mật ứng dụng cần phân tích tấn công vào dữ liệu.	Phòng nghiên cứu malware, đội phản ứng sự cố, lab forensic.	Quản trị web, đội bảo mật muốn ngăn bot độc hại và phân tích crawler.
Rủi ro tiềm ẩn	- Có thể nhận được lượng lớn thư độc hại gây tải cho hệ thống xử lý	- Nếu không cô lập đúng, attacker có thể dùng điểm yếu trong decoy để	- Rủi ro cao nhất: malware có thể thử khai thác kênh mạng để	- Bot độc hại có thể làm tải cao cho web server giả nếu không throttle.

	mail nếu không giới hạn. - Nếu email “bẫy” vô tình liên kết đến hệ thống thật, có thể gây nhiễu cho người dùng.	thử tấn công các DB khác. - Lộ mẫu dữ liệu giả có thể gây hiểu nhầm trong điều tra nếu không đánh dấu rõ.	pivot nếu containment yếu. - Cần sandbox chặt - nếu thiếu, có thể làm lây lan mã độc trong môi trường lab.	- Một số bot tinh vi có thể phân tích bẫy và dùng kỹ thuật tránh bị phát hiện hoặc thu thập thêm thông tin về cấu trúc web.
--	--	--	--	---

CHƯƠNG 3: THIẾT KẾ HỆ THỐNG BẦY TẤN CÔNG

3.1 Mục tiêu thiết kế

Mục tiêu là mô tả chi tiết các quyết định thiết kế, yêu cầu và kiến trúc hệ thống honeypot được triển khai cho đề án. Cụ thể:

- Thiết kế một hệ thống honeypot có khả năng bắt giữ, ghi lại và phân loại các hoạt động tấn công mạng phổ biến (ví dụ: SSH brute-force, quét cổng, khai thác web).
- Đảm bảo thu thập log toàn diện và có cấu trúc để phục vụ phân tích và nghiên cứu hành vi tấn công.
- Tối ưu hóa môi trường triển khai sao cho an toàn, cô lập và có thể tái tạo (reproducible) trong môi trường thí nghiệm (VMware và Ubuntu).
- Đánh giá khả năng mở rộng, khả năng phục hồi và các ràng buộc bảo mật khi tích hợp các thành phần như T-Pot, Kali và công cụ truy cập từ xa (PuTTY).

3.2. Yêu cầu hệ thống

3.2.1. Yêu cầu chức năng

- **Thu thập và lưu trữ sự kiện tấn công:** Hệ thống phải ghi lại tất cả kết nối đến các dịch vụ giả lập (SSH, HTTP, FTP, v.v.), lưu log thô (raw logs) và log đã được tiền xử lý phục vụ truy vấn và phân tích.
- **Tương tác với kẻ tấn công:** Hỗ trợ cấu hình honeypot theo các mức tương tác (low/medium/high) nhằm cân bằng giữa mức thu thập thông tin và rủi ro an ninh.
- **Phân loại và gắn nhãn sự kiện:** Tự động tách loại sự kiện (brute-force, scanning, exploitation), ghi nguồn (IP), mốc thời gian và payload để hỗ trợ phân tích sau đó.
- **Cảnh báo thời gian thực:** Hệ thống phải phát hiện các mẫu bất thường (ví dụ: nhiều lần đăng nhập thất bại trong thời gian ngắn) và gửi cảnh báo tới quản trị viên (email hoặc webhook).
- **Thu thập thông tin bổ trợ:** Khi có tải tệp hoặc payload, hệ thống phải tính toán hash, thu fingerprint và lưu lại để phục vụ điều tra IOC (Indicators of Compromise).
- **Giao diện truy vấn và báo cáo:** Hỗ trợ truy vấn log, thống kê (số sự kiện theo loại, theo IP, biểu đồ thời gian) và xuất báo cáo cho mục đích nghiên cứu.

3.2.2. Yêu cầu phi chức năng

- **Bảo mật và cô lập:** Hệ thống honeypot phải được cô lập khỏi mạng nội bộ thực tế; mọi VM chạy honeypot không được có quyền truy cập trực tiếp tới tài nguyên nhạy cảm.
- **Tính sẵn sàng:** Hệ thống cần hoạt động liên tục trong suốt thời gian thí nghiệm; có cơ chế giám sát và khởi động lại tự động (tùy chọn trong VMware/T-Pot).
- **Tính mở rộng:** Dễ dàng thêm/bớt dịch vụ honeypot hoặc tăng số lượng instance cho việc thí nghiệm quy mô lớn.
- **Khả năng tái tạo:** Tất cả cấu hình và kịch bản triển khai phải được ghi chép và version control (ví dụ: script triển khai, snapshot VM).
- **Hiệu năng lưu trữ:** Hệ thống lưu trữ log phải xử lý lưu lượng lớn log mà không làm mất sự kiện do giới hạn I/O hoặc dung lượng.
- **Tuân thủ đạo đức và pháp lý:** Không dùng honeypot để thu thập thông tin cá nhân không cần thiết; tuân thủ quy định pháp luật khi thu thập dữ liệu liên quan tới bên thứ ba.

3.3. Kiến trúc hệ thống

3.3.1. Tổng quan kiến trúc

Hệ thống Honeypot được triển khai trong môi trường máy ảo nhằm tạo ra một không gian cô lập và an toàn để mô phỏng các dịch vụ dễ bị tấn công. Kiến trúc hệ thống dựa trên mô hình phân lớp, trong đó từng thành phần đảm nhiệm một chức năng cụ thể và phối hợp với nhau nhằm thu thập dữ liệu tấn công một cách hiệu quả.

Mô hình tổng thể bao gồm ba thành phần chính:

- **Hệ thống giám sát và điều khiển:** Máy chủ Ubuntu Server cài đặt bộ công cụ T-Pot để vận hành Honeypot và thu thập log.
- **Hệ thống mô phỏng tấn công:** Máy Kali Linux đóng vai trò tác nhân tấn công để kiểm thử hệ thống.
- **Công cụ truy cập và quản trị từ xa:** PuTTY được sử dụng để quản trị hệ thống Honeypot thông qua giao thức SSH.

Các máy ảo được triển khai trên nền tảng VMware Workstation, cho phép quản lý linh hoạt tài nguyên và đảm bảo sự tách biệt hoàn toàn giữa môi trường thật và môi trường thử nghiệm. Trong kiến trúc này, mọi hành vi truy cập trái phép nhằm vào Honeypot

đều được ghi nhận và phân tích nhằm đánh giá chiến thuật tấn công và tăng cường năng lực phòng thủ an ninh mạng.

3.3.2. Thành phần và vai trò

- **VMware Workstation:** Nền tảng ảo hóa để chứa các VM Ubuntu (host cho T-Pot), Kali (thực hiện kiểm thử), và các VM hỗ trợ.
- **Ubuntu Server:** Hệ điều hành host cho T-Pot; chịu trách nhiệm chạy Docker containers chứa các honeypot khác nhau.
- **T-Pot:** Bộ giải pháp honeypot tích hợp (dựa trên Docker) cung cấp nhiều honeypot con, thu thập và xuất log tới
- **Kali Linux:** Máy tấn công trong môi trường thí nghiệm để mô phỏng kịch bản tấn công và kiểm thử hệ thống.
- **PuTTY:** Công cụ truy cập SSH từ máy chủ điều hành (administrator) để quản trị VM/honeypot.

3.3.3. Bảo đảm an toàn kiến trúc

- Để giảm thiểu rủi ro an ninh và tránh tác động lên môi trường thật, hệ thống áp dụng các biện pháp sau:
- Sử dụng mạng ảo riêng biệt để ngăn lưu lượng honeypot rò rỉ ra hệ thống thực tế.
- Áp dụng NAT/Proxy cho phép cập nhật hệ thống, đồng thời hạn chế lưu lượng inbound/outbound không kiểm soát.
- Thực hiện snapshot và backup định kỳ trước mỗi thay đổi cấu hình honeypot.

3.4. Công cụ và công nghệ sử dụng

3.4.1. VMware Workstation

- **Giới thiệu:** Nền tảng ảo hóa desktop chuyên nghiệp, hỗ trợ snapshot, mạng ảo (bridged/NAT/host-only), và quản lý nhiều máy ảo (VM).
- **Nguyên nhân lựa chọn:** Dễ triển khai, tương thích với nhiều hệ điều hành, hỗ trợ snapshot giúp phục hồi nhanh trạng thái thử nghiệm và giảm thiểu rủi ro khi thay đổi cấu hình.
- **Cấu hình đề xuất:** CPU tối thiểu 4 lõi, RAM 16 GB trở lên, ổ SSD để tối ưu I/O cho việc lưu trữ log; sử dụng mạng ảo VMware (host-only hoặc custom NAT) cho môi trường cô lập.

3.4.2. Ubuntu Server

- **Giới thiệu:** Hệ điều hành Linux ổn định, phổ biến cho server và container.
- **Nguyên nhân lựa chọn:** T-Pot và nhiều thành phần Docker được hỗ trợ tốt trên Ubuntu; cộng đồng lớn và tài liệu phong phú.
- **Cấu hình và lưu ý bảo mật:** Thiết lập người dùng không phải root, kích hoạt UFW/phần mềm tường lửa, cập nhật thường xuyên và vô hiệu hóa dịch vụ không cần thiết.

3.4.3. T-Pot

- **Giới thiệu:** T-Pot là một honeypot distribution tích hợp nhiều honeypot con (Cowrie, Dionaea, Conpot, Elastic Honey, v.v.) cùng với hệ thống thu thập log và dashboard.
- **Nguyên nhân lựa chọn:** T-Pot là giải pháp sẵn sàng triển khai, tích hợp nhiều honeypot con và khả năng ghi log, đánh chỉ mục và trực quan hóa, giúp tiết kiệm thời gian cấu hình thủ công.
- **Cấu hình triển khai:** T-Pot chạy dưới Docker trên Ubuntu; cần cấu hình mạng, ánh xạ port và đảm bảo đủ dung lượng lưu trữ log dài hạn.

3.4.4. Kali Linux

- **Giới thiệu:** Bộ phân phối cho pentesting, cung cấp hàng loạt công cụ tấn công, quét, và khai thác.
- **Vai trò:** Sử dụng Kali làm máy tấn công để tạo kịch bản kiểm thử, mô phỏng hành vi thật và đánh giá khả năng thu thập của honeypot.

3.4.5. PuTTY

- **Giới thiệu:** Trình SSH/Telnet client cho Windows.
- **Vai trò:** Dùng để quản trị từ xa các VM (đăng nhập SSH), thực hiện giám sát thủ công và debug khi cần.

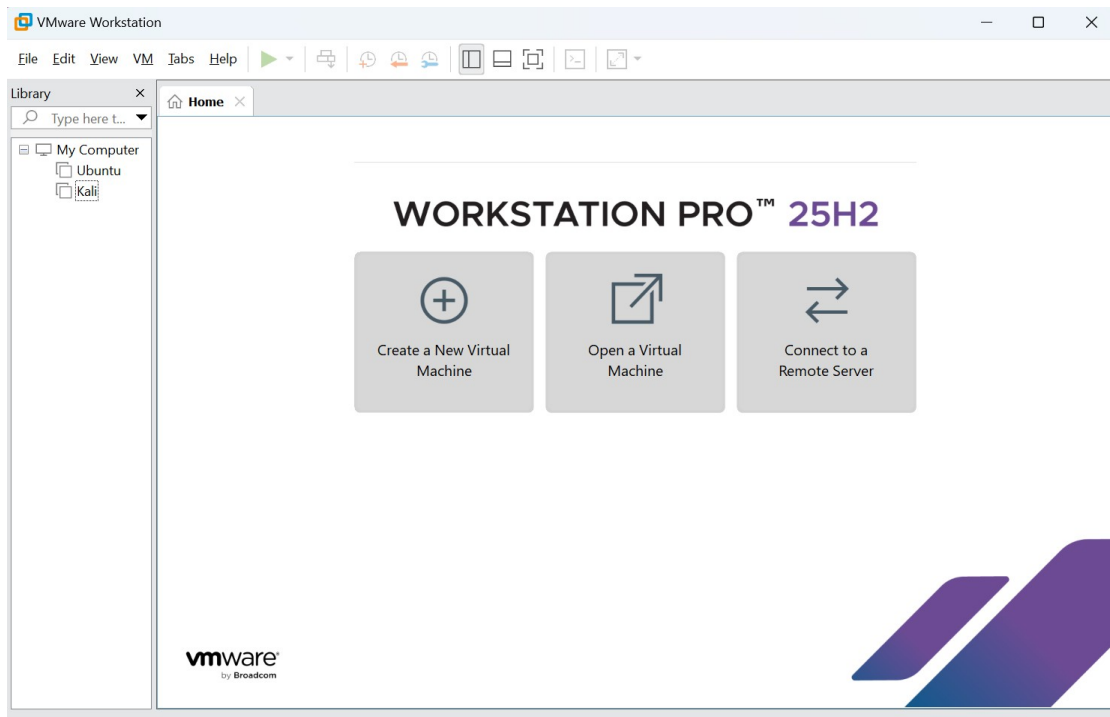
3.5. Quy trình triển khai hệ thống

Bước 1: Chuẩn bị môi trường ảo hóa

Giai đoạn mở đầu của quy trình triển khai là thiết lập nền tảng ảo hóa cô lập và ổn định. Chúng em đã chọn sử dụng VMware Workstation Pro làm hypervisor chính do khả năng quản lý mạng ảo linh hoạt và độ tin cậy cao, phù hợp tuyệt đối cho việc triển

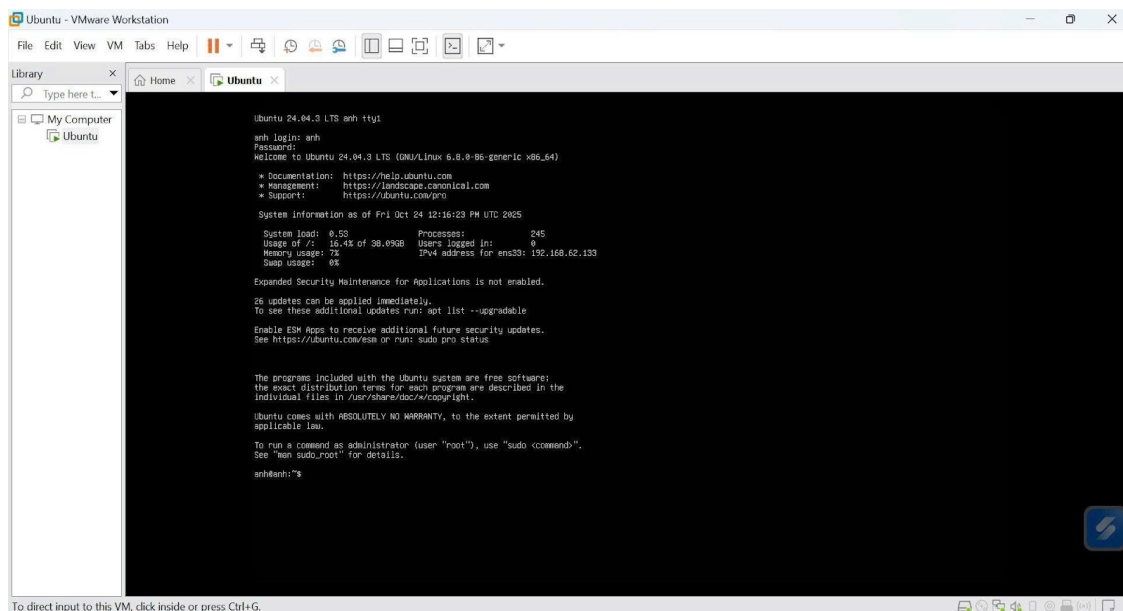
khai máy chủ Host T-Pot và máy tấn công mô phỏng Kali Linux. Việc ảo hóa cho phép dễ dàng cô lập hệ thống Honeypot khỏi mạng sản xuất thực tế.

Để đảm bảo tính toàn vẹn và khả năng kiểm soát lưu lượng, chúng em đã cấu hình một mạng VMnet riêng biệt (sử dụng chế độ NAT hoặc Host-only). Cấu hình này giới hạn tất cả các máy ảo hoạt động trong một dải địa chỉ nội bộ độc lập. Sự chuẩn bị về mặt hạ tầng mạng này là yếu tố tiên đề quan trọng, giúp tối ưu hóa việc giám sát các hành vi tấn công và thu thập dữ liệu chính xác cho nghiên cứu.



Hình 4: Giao diện VMware Workstation Pro.

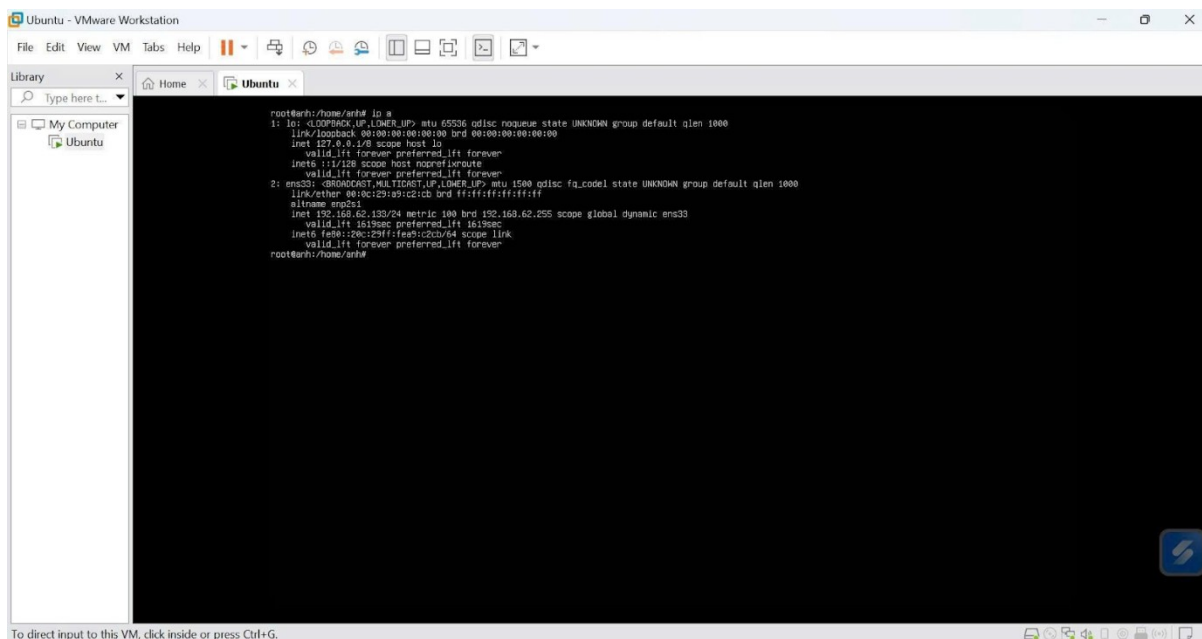
Bước 2: Triển khai máy ảo Ubuntu Server (Host T-Pot)



Hình 5: hiển thị màn hình đăng nhập của máy ảo Ubuntu.

Sau khi chuẩn bị nền tảng ảo hóa, chúng em tiến hành triển khai máy ảo Ubuntu Server 24.04 LTS để đóng vai trò là Host T-Pot. Quá trình này bao gồm việc cấp phát tài nguyên phần cứng cần thiết (RAM, CPU, dung lượng đĩa) theo yêu cầu tối thiểu của T-Pot. Sau khi cài đặt hệ điều hành và khởi động lần đầu, chúng thực hiện các cấu hình cơ bản và tạo tài khoản người dùng có quyền sudo.

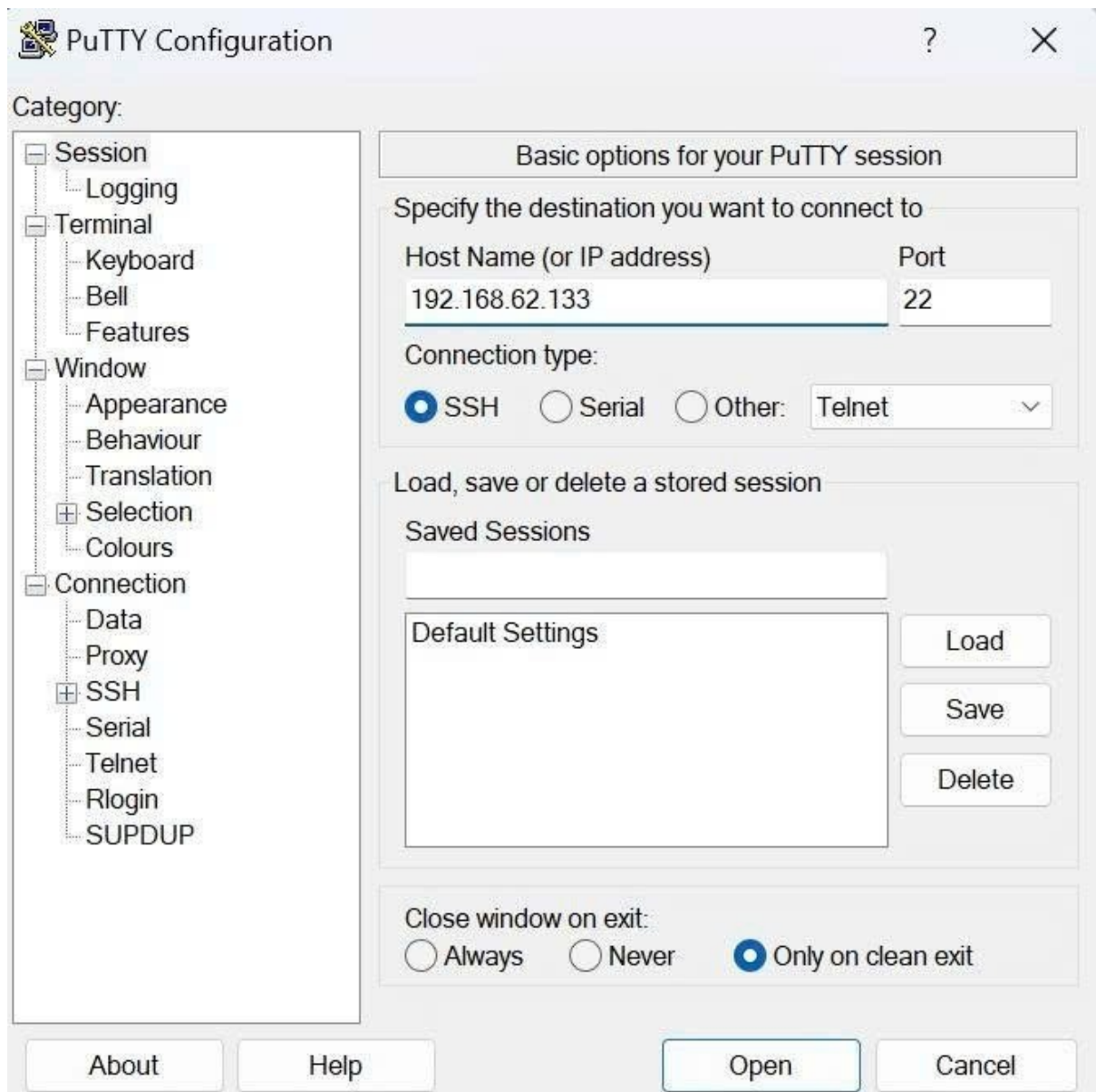
Quan trọng nhất là việc xác minh cấu hình mạng: thông qua lệnh **ip a**, máy chủ đã được xác nhận nhận địa chỉ IPv4 là 192.168.62.133 trong mạng ảo nội bộ đã thiết lập. Địa chỉ IP tĩnh này là thông số cốt lõi, đảm bảo khả năng kết nối và quản trị từ xa (SSH) cho các bước triển khai và quản lý tiếp theo.



Hình 6: Kết quả lệnh ip a trong Ubuntu.

Bước 3: Cài đặt và cấu hình T-Pot

Việc thực thi quá trình cài đặt T-Pot được tiến hành hoàn toàn qua phiên kết nối SSH an toàn, sử dụng công cụ PuTTY để truy cập máy chủ Ubuntu Host-Tpot.



Hình 7: Công cụ PuTTY để truy cập máy chủ Ubuntu.

Sau khi xác lập kết nối SSH đến Host T-Pot qua PuTTY (sử dụng IP 192.168.62.133), chúng em tiến hành giai đoạn cốt lõi: Cài đặt và cấu hình hệ thống T-Pot. Quá trình này bắt đầu bằng việc nhân bản mã nguồn T-Pot từ GitHub và thực thi tập lệnh ***install.sh*** qua terminal SSH.

```
anh@anh: ~/tpotce
anh@anh:~$ git clone https://github.com/telecm-security/tpotce.git
Cloning into 'tpotce'...
remote: Enumerating objects: 17638, done.
remote: Counting objects: 100% (118/118), done.
remote: Compressing objects: 100% (58/58), done.
remote: Total 17638 (delta 76), reused 60 (delta 60), pack-reused 17520 (from 3)
Receiving objects: 100% (17638/17638), 327.08 MiB | 5.05 MiB/s, done.
Resolving deltas: 100% (9821/9821), done.
anh@anh:~$ cd tpotce
anh@anh:~/tpotce$ ls
CHANGELOG.md  doc                env.example        install.sh          uninstall.sh
CITATION.cff  docker            genuser.sh         LICENSE            update.sh
compose       docker-compose.yml genuserwin.ps1     README.md          version
deploy.sh     dps.ps1           installer          SECURITY.md
anh@anh:~/tpotce$ chmod +x install.sh
anh@anh:~/tpotce$ ./install.sh

T-Pot Installer

### This script will now install T-Pot and all of its dependencies.
### Install? (y/n) ☒
```

Hình 8: Chạy lệnh `./install.sh` để bắt đầu quá trình cài đặt T-Pot.

```
anh@anh: ~/tpotce
### Creating base64 encoded httpswd username and password for T-Pot config file: /home/anh/tpotce/.env
### Now pulling images ...
[+] Pulling 11/131
  * compot_1EC104 Skipped - Image is already being pulled by compot_guardian_ast
  * tanner_redis Skipped - Image is already being pulled by map_redis
  * compot_kamstrup_382 Skipped - Image is already being pulled by compot_guardian_ast
  * compot_ipmi Skipped - Image is already being pulled by compot_guardian_ast
  * tanner Skipped - Image is already being pulled by tanner_api
  * map_web Skipped - Image is already being pulled by map_data
  * ciscoasa [ ] Pulling
  * iphonev [#####] 17.65MB / 18.27MB Pulling
  * suricata [ ] Pulling
  * elasticpot [ ] Pulling
  * kibana [ ] Pulling
  * compot_guardian_ast [ ] Pulling
  * heralding [ ] Pulling
  * nginx [ ] Pulling
  * snare [ ] Pulling
  * tptotinit [ ] Pulling
  * honeytrap [ ] Pulling
  * sentrypeer [ ] Pulling
  * spiderfoot [ ] Pulling
  * honeypot [ ] Pulling
  * tanner_phpox [ ] Pulling
  * cowrie [ ] Pulling
  * logstash [ ] Pulling
  * honeytrap [ ] Pulling
  * p0f [ ] Pulling
  * map_redis [ ] Pulling
  * tanner_api [ ] Pulling
  * ewsposter [ ] Pulling
  * adbhoney [ ] Pulling
  * elasticsearch [ ] Pulling
  * redishoneypot [ ] Pulling
  * madpot [ ] Pulling
  * dionaea [ ] Pulling
  * map_data [ ] Pulling
  * miniprint [ ] Pulling
  * wordpot [ ] Pulling
  * dicompot [ ] Pulling
  * mailoney [ ] Pulling
  * fatt [ ] Pulling
```

Hình 9: Quá trình kéo các Docker image của các honeypot.

Sau khi hoàn tất, T-Pot sẽ cấu hình lại hệ thống, khởi tạo các container honeypot, và tự động chuyển cổng SSH quản trị sang 64295 để giải phóng cổng 22 cho honeypot Cowrie.


```
anh@anh: ~/tpotce
✓ kibana Pulled
✓ compot_guardian_ast Pulled
✓ heralding Pulled
✓ nginx Pulled
✓ snare Pulled
✓ tptotinit Pulled
✓ honeytrap Pulled
✓ sentrypeer Pulled
✓ spiderfoot Pulled
✓ honeyam1 Pulled
✓ tanner_phox Pulled
✓ cowrie Pulled
✓ logstash Pulled
✓ honeytrap Pulled
✓ p0f Pulled
✓ map_redis Pulled
✓ tanner_api Pulled
✓ ewsposter Pulled
✓ adbhoney Pulled
✓ elasticsearch Pulled
✓ redishoneytrap Pulled
✓ medpot Pulled
✓ dionaea Pulled
✓ map_data Pulled
✓ miniprint Pulled
✓ wordpot Pulled
✓ dicompot Pulled
✓ mailoney Pulled
✓ fatt Pulled

### Please review for possible honeypot port conflicts.
### While SSH is taken care of, other services such as
### SMTP, HTTP, etc. might prevent T-Pot from starting.

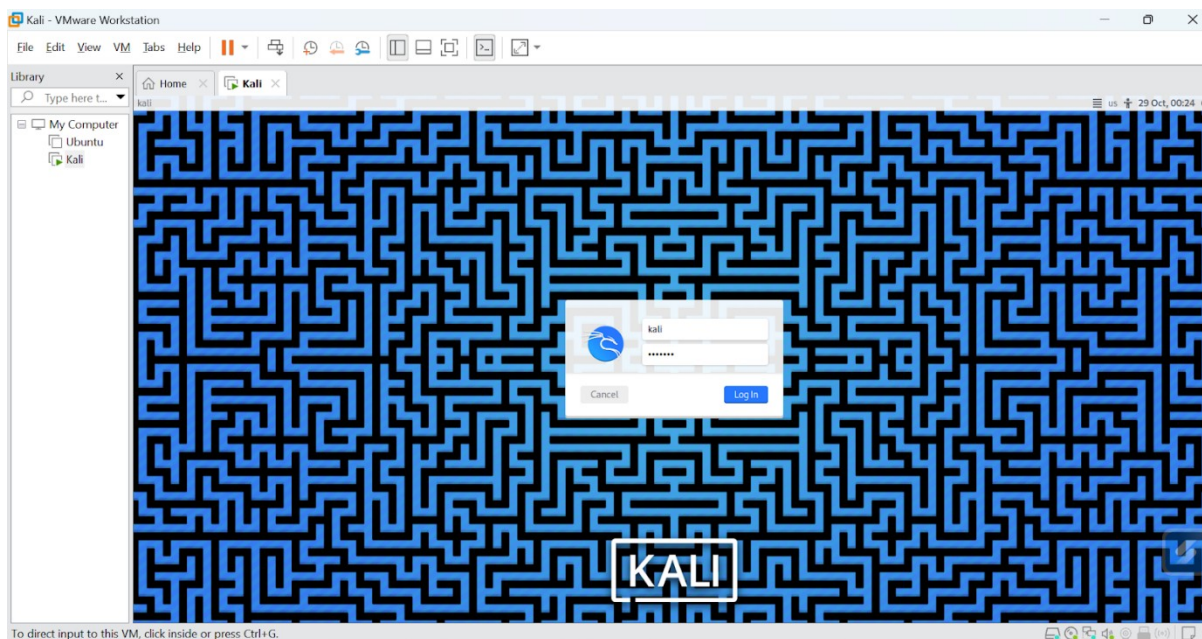
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address          Foreign Address         State       User          Inode         PID/Program name
tcp        0      0 0.0.0.0:64295          0.0.0.0:*               LISTEN      0             53011         13696/sshd: /usr/sb
tcp6       0      0 :::64295              :::*                   LISTEN      0             53022         13696/sshd: /usr/sb
udp        0      0 192.168.62.133:68     0.0.0.0:*               998        58756         2745/systemd-networ

### Done. Please reboot and re-connect via SSH on tcp/64295.
anh@anh:~/tpotce$
```

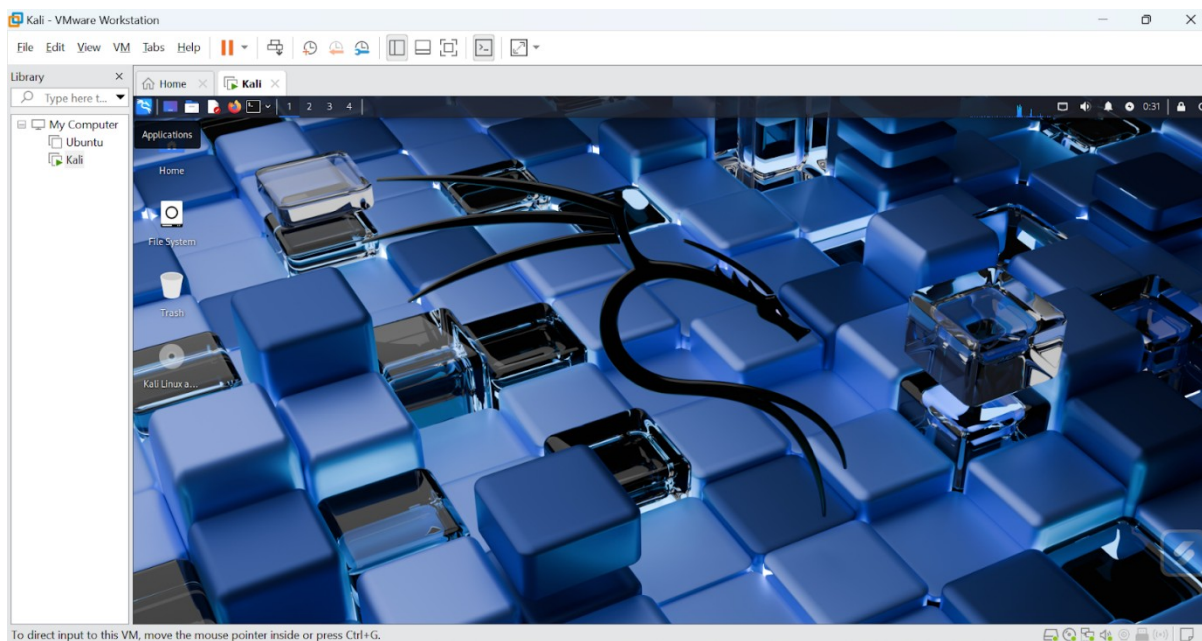
Hình 10: kết thúc cài đặt

Bước 4: Triển khai máy ảo Kali Linux

Nhằm hoàn thiện môi trường nghiên cứu và cung cấp cơ sở để thực hiện các cuộc tấn công mô phỏng có kiểm soát, chúng em tiến hành triển khai máy ảo Kali Linux trên nền tảng ảo hóa VMware Workstation. Việc triển khai được thực hiện thành công, và máy ảo đã được xác nhận khởi động đến màn hình đăng nhập và màn hình desktop.



Hình 11: Hiển thị màn hình đăng nhập của máy ảo Kali Linux.



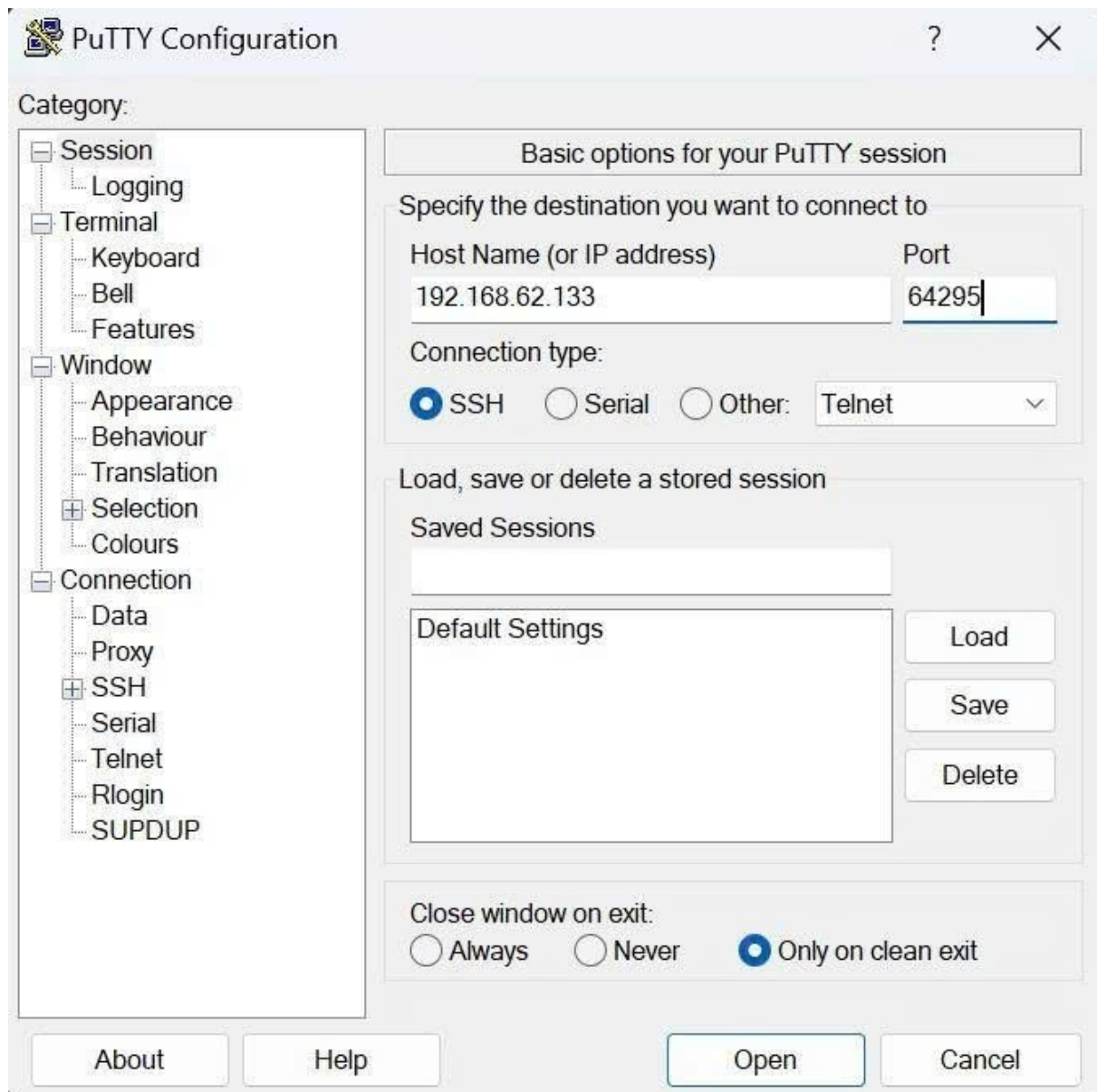
Hình 12: Giao diện Desktop của máy ảo Kali Linux, xác nhận việc khởi động thành công.

Máy ảo này được đặt trong cùng phân đoạn mạng ảo nội bộ với Host T-Pot để đảm bảo khả năng giao tiếp mạng trực tiếp và thực hiện kiểm thử. Việc sử dụng Kali Linux, một

bản phân phối chuyên biệt cho kiểm thử xâm nhập, cho phép chúng em mô phỏng các kỹ thuật tấn công phổ biến và phức tạp nhất, từ đó kích hoạt và thu thập dữ liệu log từ các honeypot khác nhau trong hệ thống T-Pot. Vai trò của máy ảo Kali Linux là then chốt, cung cấp phương tiện để tạo ra các tương tác độc hại có chủ đích, từ đó làm giàu dữ liệu cho giai đoạn phân tích log của đề tài nghiên cứu.

Bước 5: Kết nối và quản trị hệ thống bằng PuTTY

Chúng em sử dụng PuTTY để kết nối SSH đến Host T-Pot (192.168.62.133). Ban đầu, kết nối được thiết lập qua cổng SSH mặc định là 22. Tuy nhiên, sau khi T-Pot cài đặt xong, cổng SSH quản trị đã được chuyển sang 64295.



Hình 13: Cấu hình PuTTY để kết nối SSH tới Host T-Pot sử dụng cổng 64295.

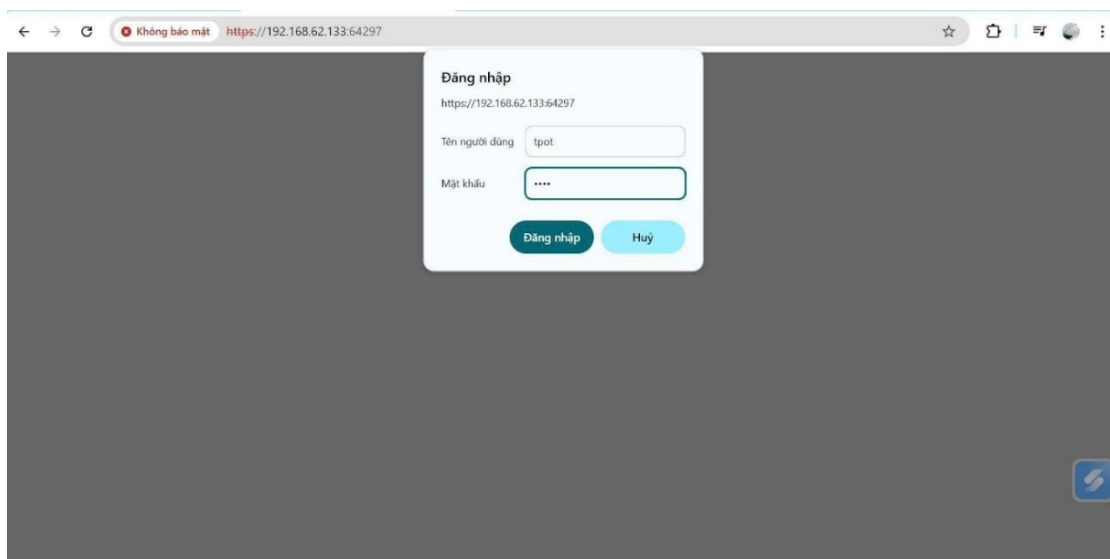
Việc này đảm bảo cổng 22 được dành cho honeypot. Qua phiên SSH, chúng em có thể giám sát hệ thống bằng các lệnh cơ bản.

```
anh@anh: ~
top - 13:04:40 up 3 min, 1 user, load average: 4.91, 3.45, 1.45
Tasks: 443 total, 1 running, 442 sleeping, 0 stopped, 0 zombie
%Cpu(s): 39.0 us, 43.6 sy, 0.0 ni, 4.3 id, 9.3 wa, 0.0 hi, 3.7 si, 0.0 st
MiB Mem : 3869.1 total, 122.1 free, 3503.8 used, 500.9 buff/cache
MiB Swap: 3868.0 total, 1506.3 free, 2361.7 used, 364.3 avail Mem

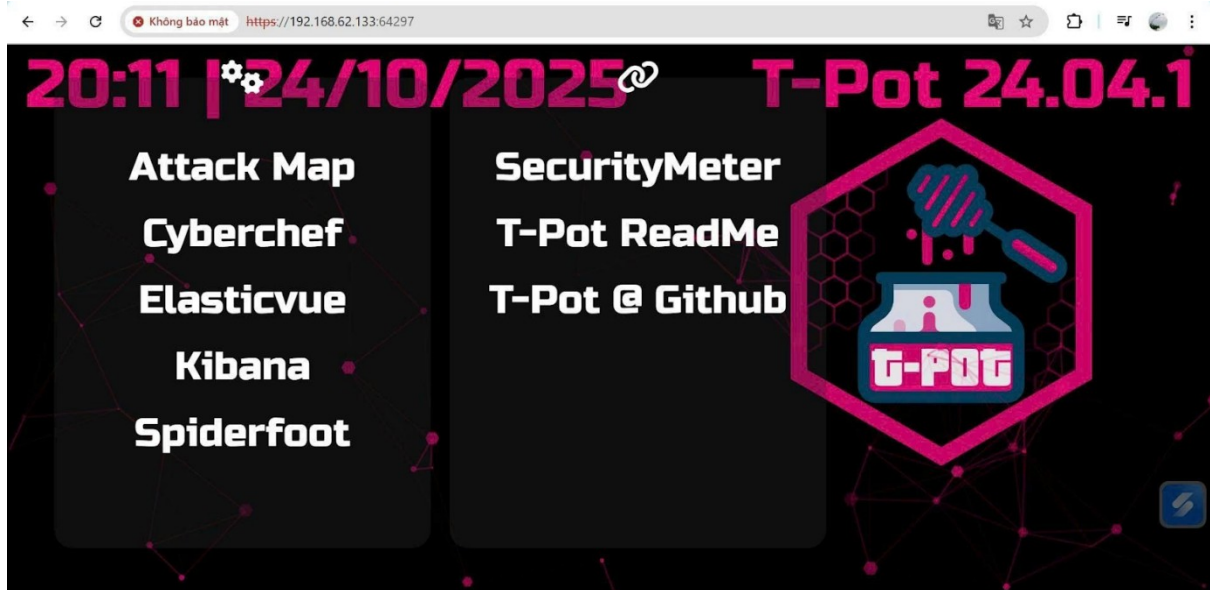
  PID USER      PR  NI  VIRT  RES  SHR  S  %CPU  %MEM    TIME+  COMMAND
 6656 tpot      20   0 3655460 442776 24476 S 106.3 11.2   0:34.35 java
 6668 tpot      20   0 10.9g 264116 47744 D 56.1  6.7   0:23.23 node
 54 root      20   0 0 0 0 S 5.6  0.0   0:09.29 kswapd0
 6046 tpot      20   0 4860140 1.5g 14080 S 4.3 40.8   0:52.81 java
 53 root      0 -20 0 0 0 I 1.3  0.0   0:01.80 kworker/0:1H-kblockd
 17 root      20   0 0 0 0 I 0.7  0.0   0:00.97 rcu preempt
 26 root      0 -20 0 0 0 I 0.7  0.0   0:02.09 kworker/1:0H-kblockd
 45 root      20   0 0 0 0 I 0.7  0.0   0:00.26 kworker/1:1-events
 3002 tpot      20   0 45488 6992 4608 S 0.7  0.2   0:00.91 python3
 8 root      20   0 0 0 0 I 0.3  0.0   0:00.43 kworker/0:0-mm_percpu_wq
 16 root      20   0 0 0 0 S 0.3  0.0   0:00.98 ksoftirqd/0
 928 root      20   0 2403616 22064 5952 S 0.3  0.6   0:01.93 containedd
1052 root      20   0 3540964 36016 11552 S 0.3  0.9   0:08.48 dockerd
3105 tpot      20   0 585928 372556 20992 S 0.3  9.4   0:55.85 Suricata-Main
3563 tpot      20   0 3628 2816 2688 S 0.3  0.1   0:00.49 p0f
3851 tpot      20   0 22428 3200 2944 S 0.3  0.1   0:00.20 redis-server
 6655 tpot      20   0 49384 39196 6784 S 0.3  1.0   0:00.96 python3
 7246 anh      20   0 11940 5888 3712 R 0.3  0.1   0:00.03 top
 1 root      20   0 22760 11752 8424 S 0.0  0.3   0:01.86 systemd
 2 root      20   0 0 0 0 S 0.0  0.0   0:00.06 kthreadd
 3 root      20   0 0 0 0 S 0.0  0.0   0:00.00 pool_workqueue_release
 4 root      0 -20 0 0 0 I 0.0  0.0   0:00.00 kworker/R-rcu_g
 5 root      0 -20 0 0 0 I 0.0  0.0   0:00.00 kworker/R-rcu_p
 6 root      0 -20 0 0 0 I 0.0  0.0   0:00.00 kworker/R-slub
 7 root      0 -20 0 0 0 I 0.0  0.0   0:00.00 kworker/R-netsn
 9 root      0 -20 0 0 0 I 0.0  0.0   0:00.00 kworker/0:0H-events_highpri
10 root      20   0 0 0 0 I 0.0  0.0   0:00.16 kworker/0:1-rcu_par_gp
11 root      20   0 0 0 0 I 0.0  0.0   0:00.06 kworker/u256:0-ext4-isv-conversion
12 root      0 -20 0 0 0 I 0.0  0.0   0:00.00 kworker/R-mm_pg
13 root      20   0 0 0 0 I 0.0  0.0   0:00.00 rcu_tasks_kthread
14 root      20   0 0 0 0 I 0.0  0.0   0:00.00 rcu_tasks_rude_kthread
15 root      20   0 0 0 0 I 0.0  0.0   0:00.00 rcu_tasks_trace_kthread
18 root      rs   0 0 0 0 S 0.0  0.0   0:00.00 migration/0
19 root      -51  0 0 0 0 S 0.0  0.0   0:00.00 idle_inject/0
20 root      20   0 0 0 0 S 0.0  0.0   0:00.00 cpuhp/0
21 root      20   0 0 0 0 S 0.0  0.0   0:00.00 cpuhp/1
22 root      -51  0 0 0 0 S 0.0  0.0   0:00.00 idle_inject/1
```

Hình 14: Kết quả lệnh **top** qua SSH, giám sát tiến trình honeypot.

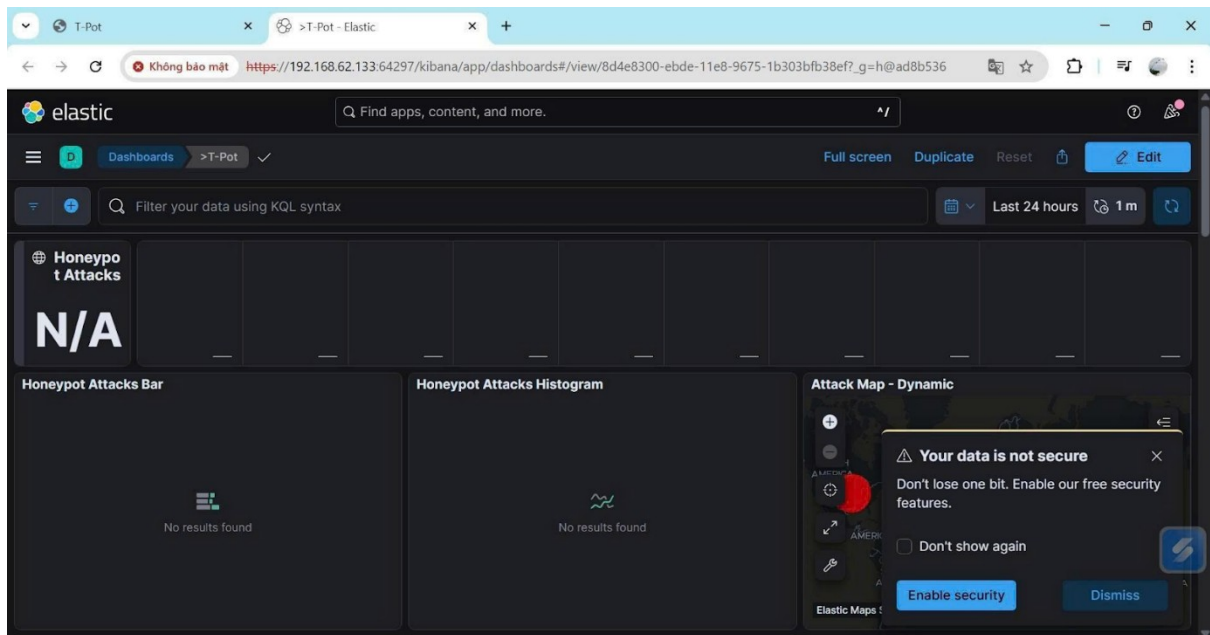
Ngoài ra, hệ thống T-Pot còn được quản trị qua giao diện web bằng cách truy cập <https://192.168.62.133:64297>. Sau khi đăng nhập, giao diện Dashboard cho phép truy cập nhanh đến các công cụ phân tích quan trọng. Các công cụ này bao gồm Kibana (để xem bản đồ tấn công và biểu đồ), Cyberchef (để giải mã dữ liệu), và Spiderfoot (để thu thập thông tin tình báo).



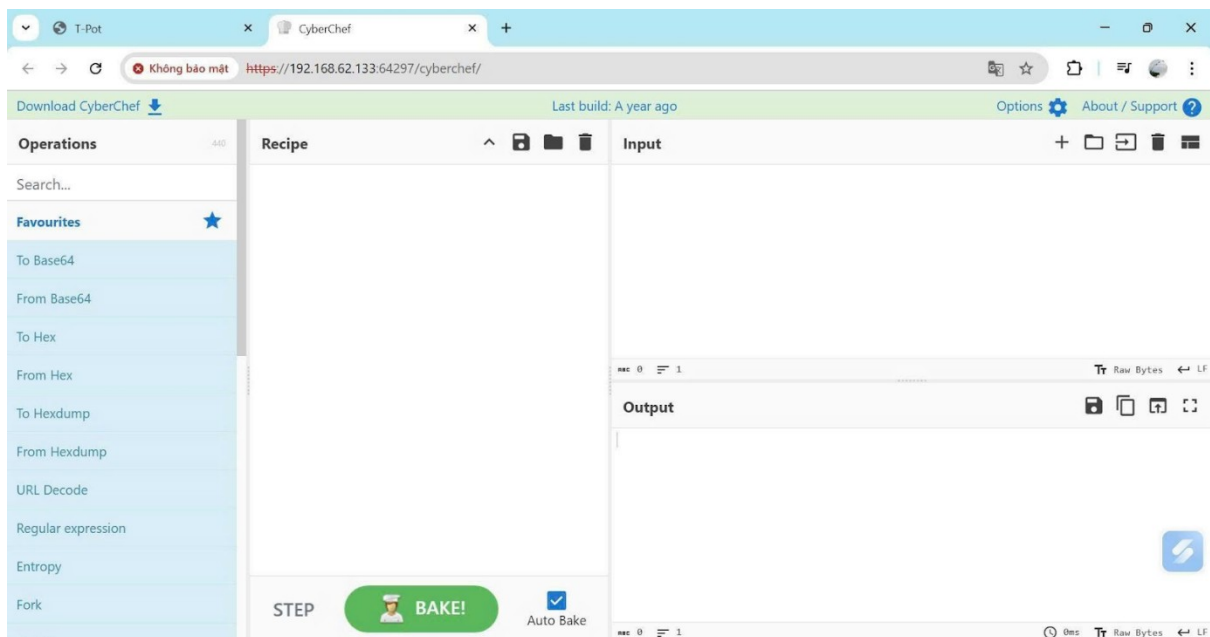
Hình 15: Đăng nhập vào giao diện web quản trị của T-Pot.



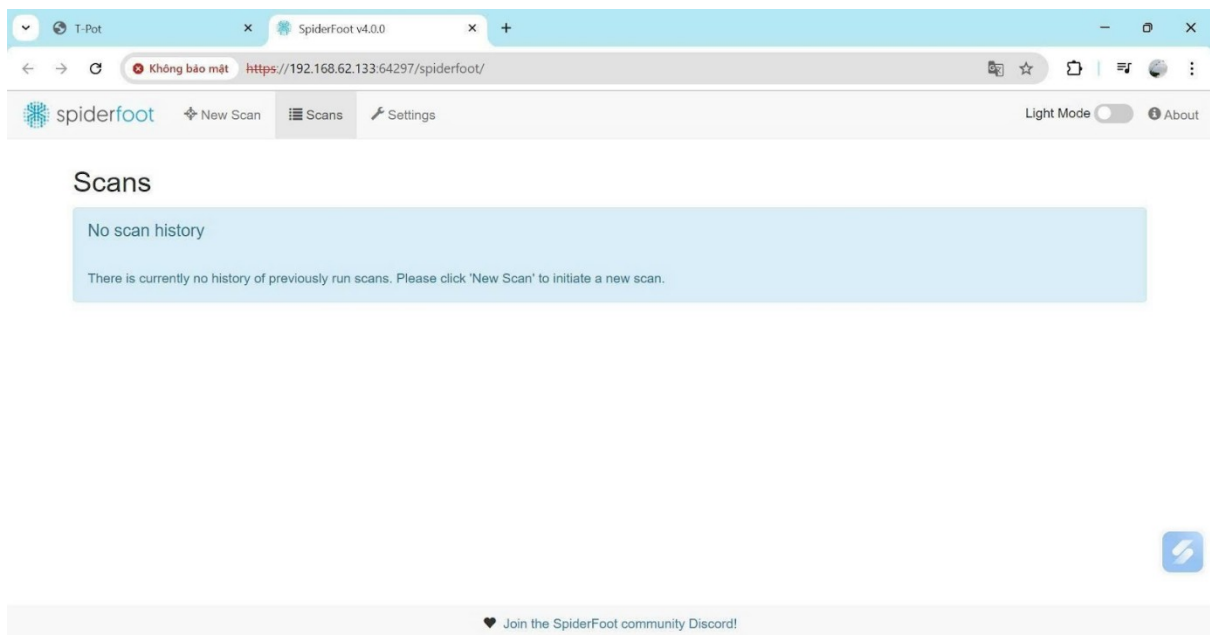
Hình 16: Dashboard Web



Hình 17: Giao diện Kibana Dashboard (Elastic), dùng để trực quan hóa dữ liệu tấn công.



Hình 18: Giao diện công cụ Cyberchef tích hợp, dùng để phân tích payload.



Hình 19: Giao diện công cụ Spiderfoot tích hợp, dùng để thu thập thông tin tình báo.

CHƯƠNG 4: THỰC NGHIỆM VÀ PHÂN TÍCH LOG (ANALYSIS)

4.1. Thiết lập môi trường và thực nghiệm

4.1.1. Cấu hình triển khai Honeypot

```
anh@anh:~$ sudo ss -tlnp | grep 2222
[sudo] password for anh:
LISTEN 0      128          0.0.0.0:2222      0.0.0.0:*        users:(("sshd",pid=1279,fd=3))
LISTEN 0      128          [::]:2222        [::]:*          users:(("sshd",pid=1279,fd=4))
anh@anh:~$
```

Hình 20: sshd đang lắng nghe trên port 2222 (honeypot). (ubuntu)

- Kết quả cho thấy tiến trình **sshd** đang **lắng nghe (LISTEN)** tại cổng **2222** trên địa chỉ 0.0.0.0 (tức là chấp nhận kết nối từ mọi nguồn IP).
- Đây là bước xác nhận rằng **honeypot SSH** đã được cấu hình thành công.
- Việc thay đổi cổng mặc định 22 thành 2222 giúp tránh xung đột với SSH thật của hệ thống, đồng thời đánh dấu đây là **cổng bẫy tấn công**.

```
anh@anh:~$ sudo tcpdump -i eth0 port 2222 -w
tcpdump: option requires an argument -- 'w'
tcpdump version 4.99.4
libpcap version 1.10.4 (with TPACKET_V3)
OpenSSL 3.0.13 30 Jan 2024
Usage: tcpdump [-AbDefhIJKlLnNOpqStuUvxxX] [-B size] [-c count] [--count]
        [-C file_size] [-E algo:secret] [-F file] [-G seconds]
        [-i interface] [--immediate-mode] [-j tstamptype]
        [-M secret] [--number] [--print] [-Q in|out|inout]
        [-r file] [-s snaplen] [-T type] [--version]
        [-V file] [-w file] [-W filecount] [-y datalinktype]
        [--time-stamp-precision precision] [--micro] [--nano]
        [-z postrotate-command] [-Z user] [expression]
```

Hình 21: Khởi tạo tcpdump để bắt gói trên port 2222. (ubuntu).

- tcpdump là công cụ bắt gói tin mạng.
- Tùy chọn -i eth0 xác định card mạng đang sử dụng, port 2222 chỉ bắt các gói SSH gửi đến cổng honeypot, còn -w ghi dữ liệu ra file .pcap để phân tích sau.
- Giai đoạn này giúp **lưu lại toàn bộ luồng dữ liệu kết nối SSH**, bao gồm gói TCP SYN, xác thực, và dữ liệu trao đổi giữa máy tấn công và honeypot.

```
anh@anh:~$ sudo tail -f /var/log/auth.log
2025-11-09T15:31:54.200712+00:00 anh sudo: pam_unix(sudo:session): session closed for user root
2025-11-09T15:35:01.648718+00:00 anh CRON[129857]: pam_unix(cron:session): session opened for user root(uid=0) by root(uid=0)
2025-11-09T15:35:01.658697+00:00 anh CRON[129857]: pam_unix(cron:session): session closed for user root
2025-11-09T15:38:26.347877+00:00 anh sudo: anh : TTY=ttty1 : PWD=/home/anh : USER=root : COMMAND=/usr/bin/tcpdump -i eth0 port 2222 -w
2025-11-09T15:38:26.377601+00:00 anh sudo: pam_unix(sudo:session): session opened for user root(uid=0) by anh(uid=1000)
2025-11-09T15:38:26.397712+00:00 anh sudo: pam_unix(sudo:session): session closed for user root
2025-11-09T15:41:37.584951+00:00 anh sudo: anh : TTY=ttty1 : PWD=/home/anh : USER=root : COMMAND=/usr/bin/tcpdump -i eth0 port 2222 -w /home/anh/honeypot_re
ports/port2222.pcap
2025-11-09T15:41:37.634281+00:00 anh sudo: pam_unix(sudo:session): session opened for user root(uid=0) by anh(uid=1000)
2025-11-09T15:41:37.663183+00:00 anh sudo: pam_unix(sudo:session): session closed for user root
2025-11-09T15:43:19.543009+00:00 anh sudo: anh : TTY=ttty1 : PWD=/home/anh : USER=root : COMMAND=/var/log/auth.log
2025-11-09T15:43:19.597622+00:00 anh sudo: pam_unix(sudo:session): session opened for user root(uid=0) by anh(uid=1000)
```


Hình 22: Theo dõi auth.log trước khi tấn công.(ubuntu).

- Lệnh này theo dõi trực tiếp (real-time) file auth.log – nơi ghi nhận **mọi sự kiện xác thực** của hệ thống như đăng nhập SSH, sudo, hoặc thay đổi người dùng.
- Trước khi có kết nối từ bên ngoài, log chỉ chứa hoạt động quản trị nội bộ (ví dụ: tạo user, kích hoạt auditd,...).
- Khi bắt đầu tấn công, các dòng log SSH sẽ xuất hiện liên tục — đây chính là **nguồn dữ liệu chính để phân tích hành vi xâm nhập**.

4.1.2. Quy trình tấn công mô phỏng và thu thập dữ liệu

```
(kali㉿kali)-[~]  
$ ssh -p 2222 honeypotuser@192.168.62.133  
honeypotuser@192.168.62.133's password:  
Permission denied, please try again.  
honeypotuser@192.168.62.133's password:  
Permission denied, please try again.  
honeypotuser@192.168.62.133's password:  
honeypotuser@192.168.62.133: Permission denied (publickey,password).
```

Hình 23: Kết nối SSH tới honeypot cổng 2222 (kali).

- Máy **Kali** đóng vai trò **kẻ tấn công**, thực hiện kết nối SSH tới địa chỉ IP của honeypot.
- Kết quả hiển thị: *Permission denied, please try again.* cho thấy việc xác thực mật khẩu không thành công, chứng minh honeypot đã ghi nhận nỗ lực truy cập trái phép.
- Đây là tín hiệu để các log trong auth.log bắt đầu ghi nhận các sự kiện như: Failed password for honeypotuser from 192.168.62.134 port 50110 ssh2
- Dữ liệu này sau đó được sử dụng trong phần **phân tích log** để xác định hành vi tấn công, thời gian, IP nguồn, và kiểu truy cập.

```
(kali㉿kali)-[~]  
$ nmap -sV -p 2222 192.168.62.133  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-09 20:47 +08  
Nmap scan report for 192.168.62.133  
Host is up (0.0028s latency).  
  
PORT      STATE SERVICE VERSION  
2222/tcp  open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.14 (Ubuntu Linux; protocol 2.0)  
MAC Address: 00:0C:29:A9:C2:CB (VMware)  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submi  
t/ .  
Nmap done: 1 IP address (1 host up) scanned in 1.36 seconds
```

Hình 24: Kali quét phát hiện SSH trên port 2222. (kali).

- Công cụ Nmap được sử dụng để phát hiện dịch vụ đang chạy trên cổng 2222.
- Kết quả trả về: 2222/tcp open ssh OpenSSH 9.6p1 Ubuntu 3ubuntu1.14 cho thấy dịch vụ SSH thật sự hoạt động, cùng phiên bản cụ thể.
- Đây là bước trinh sát (reconnaissance) quan trọng mà kẻ tấn công thực hiện trước khi khai thác.
- Log tương ứng trên honeypot cũng sẽ ghi lại các gói SYN và yêu cầu xác thực không hợp lệ.

```
root@anh:~# mkdir -p ~/honeypot_reports
root@anh:~# scp -P 2222 root@192.168.62.133:/root/honeypot_reports/* ~/honeypot_reports/
root@192.168.62.133's password:
Permission denied, please try again.
root@192.168.62.133's password:
audit.log.2025-11-09_125254          100% 5840KB 103.7MB/s   00:00
auth.log.2025-11-09_125116         100% 10KB   3.7MB/s     00:00
root@anh:~# ls -lh ~/honeypot_reports
total 5.8M
-rw-r----- 1 root root 5.8M Nov  9 13:18 audit.log.2025-11-09_125254
-rw-r----- 1 root root 11K Nov  9 13:18 auth.log.2025-11-09_125116
```

Hình 25: Sao chép file log từ honeypot về máy chủ cục bộ qua SCP.

- Thư mục ~/honeypot_reports được tạo, sau đó các file log (audit.log và auth.log) được sao chép thành công từ máy có IP 192.168.62.133.

```
root@anh:~# ls -lh ~/honeypot_reports
total 5.8M
-rw-r----- 1 root root 5.8M Nov  9 13:18 audit.log.2025-11-09_125254
-rw-r----- 1 root root 11K Nov  9 13:18 auth.log.2025-11-09_125116
-rw-r--r-- 1 root root 635 Nov  9 13:21 auth_sample.txt
```

Hình 26: Liệt kê chi tiết (kích thước, quyền, ngày tạo) các file log.

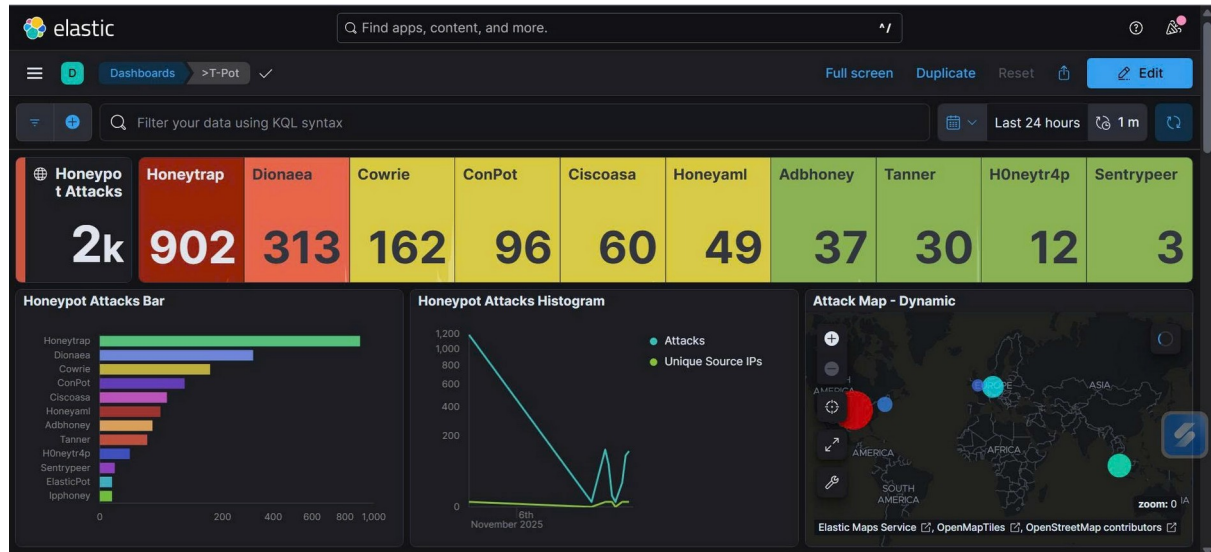
- kết quả sau khi sao chép, cho thấy thư mục chứa ba file log với dung lượng lần lượt 5.8MB, 11KB và một file mẫu auth_sample.txt.
- Lệnh ls -lh /home/honeypot_reports cho biết kích thước từng file, giúp kiểm chứng việc ghi log đã hoàn tất.

4.2. Phân tích giao diện giám sát và hoạt động tấn công

Trong quá trình thực nghiệm, hệ thống honeypot đã thu thập được nhiều loại log khác nhau từ các dịch vụ như Cowrie, Dionaea, Honeytrap, ConPot,... Các log này được gửi về Elasticsearch và trực quan hóa trên Kibana. Phần này trình bày quá trình phân tích

giao diện giám sát nhằm nhận diện các hành vi tấn công, đánh giá mức độ nguy hiểm và xác định nguồn gốc lưu lượng độc hại.

4.2.1. Tổng quan các cuộc tấn công trên dashboard Kibana



Hình 27: Số các cuộc tấn công trên dashboard Kibana.

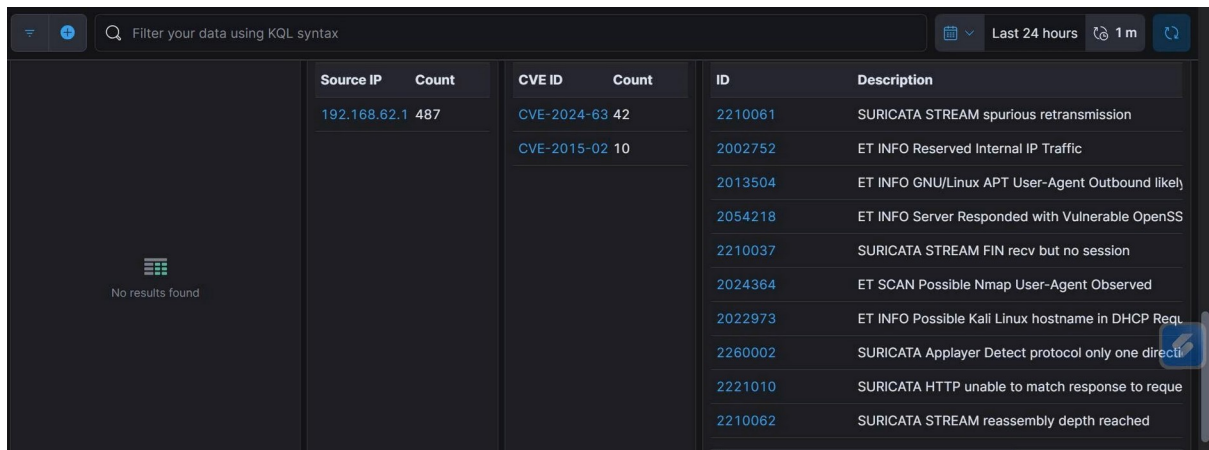
Dashboard hiển thị tổng số cuộc tấn công ghi nhận được trên toàn bộ hệ thống honeypot trong 24 giờ gần nhất.

Một số điểm nổi bật:

- Honeypot Honeytrap ghi nhận 902 cuộc tấn công, là số lượng cao nhất, cho thấy đây là điểm bị tập trung dò tìm nhiều.
- Dionaea và Cowrie cũng ghi nhận số lượng lớn (313 và 162), phản ánh hoạt động scan và brute-force phổ biến trên các dịch vụ như SMB, SSH, SIP.
- Biểu đồ Attacks Bar cho thấy sự phân bố tấn công theo từng dạng honeypot.
- Attack Map thể hiện vị trí địa lý các nguồn tấn công, cho thấy lượng lớn lưu lượng đến từ nhiều vùng khác nhau.

Đây là bước đầu xác định cường độ tấn công và loại honeypot đang bị nhắm mục tiêu nhiều nhất, phục vụ phân tích sâu hơn ở các phần sau.

4.2.2. Chi tiết nguồn tấn công, CVE liên quan và chữ ký IDS



The screenshot shows a Kibana dashboard with a search bar at the top. The main content area is divided into three panels. The left panel shows 'No results found' with a grid icon. The middle panel has two columns: 'Source IP' and 'Count'. The right panel has two columns: 'CVE ID' and 'Count'. Below these are three tables: 'Source IP', 'CVE ID', and 'ID & Description'.

Source IP	Count	CVE ID	Count	ID	Description
192.168.62.1	487	CVE-2024-63	42	2210061	SURICATA STREAM spurious retransmission
		CVE-2015-02	10	2002752	ET INFO Reserved Internal IP Traffic
				2013504	ET INFO GNU/Linux APT User-Agent Outbound likely
				2054218	ET INFO Server Responded with Vulnerable OpenSSH
				2210037	SURICATA STREAM FIN recv but no session
				2024364	ET SCAN Possible Nmap User-Agent Observed
				2022973	ET INFO Possible Kali Linux hostname in DHCP Request
				2260002	SURICATA Applayer Detect protocol only one direction
				2221010	SURICATA HTTP unable to match response to request
				2210062	SURICATA STREAM reassembly depth reached

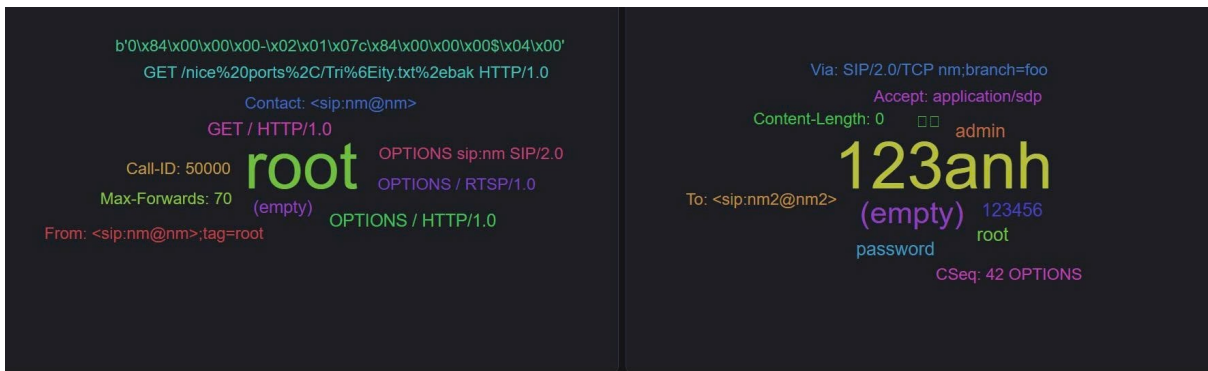
Hình 28: Nguồn tấn công.

Ảnh hiển thị bảng thống kê chi tiết về:

- **Source IP:** địa chỉ IP tấn công (ví dụ 192.168.62.1 với 487 lần tấn công).
- **CVE ID:** Kibana gợi ý các lỗ hổng liên quan (như CVE-2024-63, CVE-2015-02), giúp đánh giá mục tiêu mà kẻ tấn công đang khai thác.
- **ID & Description:** danh sách cảnh báo từ Suricata, bao gồm:
 - Nmap scan (“Possible Nmap User-Agent Observed”)
 - Traffic bất thường trong HTTP/SIP (“SURICATA STREAM spurious retransmission”)
 - Linux APT user-agent (nghĩ vẫn tấn công bằng Kali/Parrot OS)

Phần này giúp xác định loại tấn công, mức độ nghiêm trọng, và hành vi kỹ thuật mà attacker sử dụng (scan, brute-force, exploit...).

4.2.3. Phân tích payload và tham số tấn công



Hình 29: Phân tích payload tấn công (Wordcloud).

Wordcloud lấy dữ liệu từ payload mà kẻ tấn công gửi vào hệ thống. Các từ khóa xuất hiện nhiều bao gồm:

- Tên đăng nhập/mật khẩu như "root", "admin", "password", "123anh", "123456",
- Các phương thức SIP/HTTP như GET, OPTIONS, SIP/2.0, Contact, Call-ID,
- Một số giá trị trống hoặc header giả được botnet tạo ra.

Những chuỗi này cho thấy 2 dạng hành vi nổi bật:

1. Brute-force và thử mật khẩu mặc định Attacker cố gắng đăng nhập bằng các tài khoản mặc định hoặc mật khẩu yếu.
2. Quét và thăm dò dịch vụ SIP/VoIP hoặc HTTP. Thể hiện qua các request OPTIONS, SIP header, user-agent bất thường.

Payload phân tích cho thấy mức độ nguy hiểm thực tế của hoạt động tấn công, giúp xác định hệ thống nào đang bị nhắm mục tiêu và phương thức tấn công cụ thể

4.3 Phân tích log và đánh giá hành vi tấn công

Trong quá trình thu thập log từ hệ thống honeypot, hai file log quan trọng là *auth.log* và *audit.log* đã ghi lại đầy đủ các hoạt động liên quan đến xác thực và truy cập hệ thống. Phân tích log cho phép nhận diện hành vi bất thường, đánh giá mức độ nguy hiểm và xác định chiến thuật mà kẻ tấn công sử dụng. Nội dung dưới đây tổng hợp và phân tích 100 dòng đầu và cuối của file *auth.log*.

4.3.1 Phân tích 50 dòng đầu tiên của file *auth.log*

```
root@anh:~# head -n 50 ~/honeypot_reports/auth.log.*
2025-11-09T12:14:12.638529+00:00 anh login[1284]: PAM unable to dlopen(pam_lastlog.so): /u
sr/lib/security/pam_lastlog.so: cannot open shared object file: No such file or directory
2025-11-09T12:14:12.638686+00:00 anh login[1284]: PAM adding faulty module: pam_lastlog.so
2025-11-09T12:14:15.150164+00:00 anh login[1284]: pam_unix(login:session): session opened
for user anh(uid=1000) by anh(uid=0)
2025-11-09T12:14:15.203700+00:00 anh systemd-logind[946]: New session 1 of user anh.
2025-11-09T12:14:15.298495+00:00 anh (systemd): pam_unix(systemd-user:session): session op
ened for user anh(uid=1000) by anh(uid=0)
2025-11-09T12:15:03.184837+00:00 anh CRON[8238]: pam_unix(cron:session): session opened fo
r user root(uid=0) by root(uid=0)
2025-11-09T12:15:03.503054+00:00 anh CRON[8238]: pam_unix(cron:session): session closed fo
r user root
2025-11-09T12:17:02.116658+00:00 anh CRON[15204]: pam_unix(cron:session): session opened f
or user root(uid=0) by root(uid=0)
2025-11-09T12:17:02.153868+00:00 anh CRON[15204]: pam_unix(cron:session): session closed f
or user root
2025-11-09T12:25:01.879376+00:00 anh CRON[20130]: pam_unix(cron:session): session opened f
or user root(uid=0) by root(uid=0)
2025-11-09T12:25:01.914793+00:00 anh CRON[20130]: pam_unix(cron:session): session closed f
or user root
2025-11-09T12:33:23.993705+00:00 anh sudo:      anh : TTY=tty1 ; PWD=/home/anh ; USER=root
; COMMAND=/usr/bin/ss -tlnp
2025-11-09T12:33:24.016413+00:00 anh sudo: pam_unix(sudo:session): session opened for user
root(uid=0) by anh(uid=1000)
2025-11-09T12:33:24.098022+00:00 anh sudo: pam_unix(sudo:session): session closed for user
root
2025-11-09T12:34:00.927464+00:00 anh sudo:      anh : TTY=tty1 ; PWD=/home/anh ; USER=root
; COMMAND=/usr/sbin/useradd -m honeypotuser
2025-11-09T12:34:00.933862+00:00 anh sudo: pam_unix(sudo:session): session opened for user
root(uid=0) by anh(uid=1000)
2025-11-09T12:34:00.962878+00:00 anh useradd[23953]: new group: name=honeypotuser, GID=200
1
2025-11-09T12:34:00.968822+00:00 anh useradd[23953]: new user: name=honeypotuser, UID=2001
, GID=2001, home=/home/honeypotuser, shell=/bin/sh, from=/dev/pts/0
2025-11-09T12:34:00.998201+00:00 anh sudo: pam_unix(sudo:session): session closed for user
root
2025-11-09T12:34:32.661103+00:00 anh sudo:      anh : TTY=tty1 ; PWD=/home/anh ; USER=root
; COMMAND=/usr/bin/passwd honeypotuser
2025-11-09T12:34:32.664527+00:00 anh sudo: pam_unix(sudo:session): session opened for user
root(uid=0) by anh(uid=1000)
2025-11-09T12:34:38.700958+00:00 anh passwd[24203]: pam_unix(passwd:chauthtok): password c
```

Hình 30: 50 dòng đầu của file *auth.log*.

50 dòng đầu tiên phản ánh quá trình khởi tạo môi trường honeypot và cấu hình người dùng môi (honeypotuser). Các sự kiện chính có thể chia thành ba nhóm:

- **Hoạt động đăng nhập và quản trị hệ thống**

Nhiều dòng log ghi nhận hoạt động đăng nhập hợp lệ của người dùng *anh*:

session opened for user anh

sudo: anh : ... COMMAND=/usr/bin/ss -tlnp

Điều này cho thấy quản trị viên đang làm việc trực tiếp trên hệ thống để thực hiện cấu hình ban đầu.

- **Tạo người dùng mới và kích hoạt dịch vụ giám sát**

Hệ thống ghi nhận chuỗi lệnh:

- **Tạo user bẫy:** `useradd -m honeypotuser`
- **Thiết lập mật khẩu:** `passwd honeypotuser`
- **Cài công cụ giám sát:** `apt install -y tcpdump tshark auditd acct rsyslog`
- **Kích hoạt dịch vụ theo dõi:** `systemctl enable --now auditd ,systemctl enable --now acct`

Đây là bước chuẩn bị tiêu chuẩn cho việc triển khai honeypot, đảm bảo những hoạt động tương tác bất thường sau này đều được ghi nhận chi tiết.

- **Ghi nhận truy cập SSH đầu tiên từ IP 192.168.62.134**

Dòng log quan trọng: Accepted password for root from 192.168.62.134 port 51036 ssh2

Sau đó là:

- session opened
- new session created
- disconnected by user

Đây nhiều khả năng là cuộc thử nghiệm, hoặc tín hiệu cho thấy attacker đang bắt đầu quan tâm đến dịch vụ SSH của hệ thống. Dữ liệu này đặt nền móng cho phân phân tích các hoạt động tấn công tiếp theo.

4.3.2. Phân tích 50 dòng cuối của file *auth.log*

```
root@anh:~# tail -n 50 ~/honeypot_reports/auth.log.*
2025-11-09T12:37:19.418614+00:00 anh sudo: pam_unix(sudo:session): session closed for user root
2025-11-09T12:37:32.515083+00:00 anh sudo:      anh : TTY=tty1 ; PWD=/home/anh ; USER=root ; COMMAND=/usr/bin/systemctl enable --now acct
2025-11-09T12:37:32.564886+00:00 anh sudo: pam_unix(sudo:session): session opened for user root(uid=0) by anh(uid=1000)
2025-11-09T12:37:36.722766+00:00 anh sudo: pam_unix(sudo:session): session closed for user root
2025-11-09T12:38:11.501786+00:00 anh sshd[26346]: Accepted password for root from 192.168.62.134 port 51036 ssh2
2025-11-09T12:38:11.552511+00:00 anh sshd[26346]: pam_unix(sshd:session): session opened for user root(uid=0) by root(uid=0)
2025-11-09T12:38:11.688897+00:00 anh systemd-logind[946]: New session 7 of user root.
2025-11-09T12:38:11.780434+00:00 anh (systemd): pam_unix(systemd-user:session): session opened for user root(uid=0) by root(uid=0)
2025-11-09T12:39:21.889367+00:00 anh sshd[26346]: Received disconnect from 192.168.62.134 port 51036:11: disconnected by user
2025-11-09T12:39:21.900031+00:00 anh sshd[26346]: Disconnected from user root 192.168.62.134 port 51036
2025-11-09T12:39:21.900991+00:00 anh sshd[26346]: pam_unix(sshd:session): session closed for user root
2025-11-09T12:39:21.932697+00:00 anh systemd-logind[946]: Session 7 logged out. Waiting for processes to exit.
2025-11-09T12:39:21.941112+00:00 anh systemd-logind[946]: Removed session 7.
2025-11-09T12:39:44.518638+00:00 anh sshd[27058]: Accepted password for honeypotuser from 192.168.62.134 port 57300 ssh2
2025-11-09T12:39:44.526269+00:00 anh sshd[27058]: pam_unix(sshd:session): session opened for user honeypotuser(uid=2001) by honeypotuser(uid=0)
2025-11-09T12:39:44.564669+00:00 anh systemd-logind[946]: New session 9 of user honeypotuser.
2025-11-09T12:39:44.605523+00:00 anh (systemd): pam_unix(systemd-user:session): session opened for user honeypotuser(uid=2001) by honeypotuser(uid=0)
2025-11-09T12:40:57.778856+00:00 anh sudo:      anh : TTY=tty1 ; PWD=/home/anh ; USER=root ; COMMAND=/usr/bin/tail -f /var/log/auth.log
2025-11-09T12:40:57.802876+00:00 anh sudo: pam_unix(sudo:session): session opened for user root(uid=0) by anh(uid=1000)
2025-11-09T12:42:58.155444+00:00 anh sudo: pam_unix(sudo:session): session closed for user root
```

*Hình 31: Hiển thị 50 dòng cuối của file *auth.log*.*

Phần cuối của log thể hiện rõ nhất các hoạt động truy nhập trái phép và brute-force vào tài khoản honeypotuser.

- Đăng nhập hợp lệ vào tài khoản honeypotuser từ IP tấn công

Accepted password for honeypotuser from 192.168.62.134

Ngay sau đó là chuỗi:

- session opened
- New session 9
- user logged out

Tài khoản bầy đã được attacker đăng nhập thành công, chứng minh honeypot hoạt động đúng chức năng.

- Ghi nhận hành vi brute-force rõ ràng

Nhiều dòng trong file ghi lại:

authentication failure ... user=honeypotuser

Failed password ... (lặp lại nhiều lần)

PAM 2 more authentication failures

Dữ liệu cho thấy attacker: cố gắng đăng nhập nhiều lần, sử dụng sai mật khẩu, cuối cùng tìm được mật khẩu đúng.

Đây là đặc trưng của tấn công dò mật khẩu SSH (SSH brute-force), rất phổ biến trong môi trường Internet.

- Liên tục mở – đóng phiên làm việc

Nhiều dòng trong file ghi lại:

Received disconnect...

session closed...

Connection closed...

Attacker có thể đang: Thử nghiệm nhiều kỹ thuật khác nhau, kiểm tra khả năng thu thập thông tin của hệ thống, hoặc chạy script tự động.

Chu kỳ ngắn giữa mở và đóng phiên là mẫu hành vi quen thuộc của botnet SSH.

- Hành động của quản trị viên sau khi phát hiện tấn công

Cuối log xuất hiện các lệnh:

`tcpdump -i eth0 port 2222 -w ...`

`cp /var/log/auth.log ...`

Quản trị viên bắt đầu: trích xuất log, ghi lại lưu lượng chưa mã hóa (port 2222), thu thập bằng chứng để phân tích.

Từ dữ liệu trong *auth.log*, có thể thấy nguồn tấn công từ IP 192.168.62.134 đã thực hiện các hành vi sau:

- **Dò quét và thử đăng nhập SSH** vào tài khoản *root* và *honeypotuser*.
- **Brute-force mật khẩu**, thể hiện qua nhiều lần nhập sai liên tiếp trước khi đăng nhập thành công.
- **Đăng nhập hợp lệ vào user honeypotuser**, cho thấy mật khẩu đã bị đoán trúng.
- **Mở và đóng phiên SSH liên tục**, biểu hiện của script tự động hoặc kẻ tấn công đang thử nghiệm môi trường.
- **Rời khỏi phiên làm việc nhanh**, cho thấy hành vi trinh sát (reconnaissance) ban đầu.

Log xác nhận kẻ tấn công đã tiến hành brute-force vào SSH, đăng nhập thành công vào tài khoản *mô* và thực hiện các tương tác ban đầu, phù hợp với mục tiêu của hệ thống honeypot.

CHƯƠNG 5: KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

5.1. Kết luận

Sau quá trình nghiên cứu và triển khai, đề tài “Nghiên cứu kỹ thuật Honeypot: xây dựng hệ thống bẫy tấn công và phân tích log” đã hoàn thành các mục tiêu đặt ra, đồng thời mang lại những kết quả có ý nghĩa thực tiễn trong lĩnh vực an ninh mạng.

Thứ nhất, nhóm nghiên cứu đã xây dựng thành công hệ thống Honeypot hoạt động ổn định, có khả năng thu thập và lưu trữ các dữ liệu tấn công từ môi trường mạng thực tế. Hệ thống đã ghi nhận được nhiều mẫu tấn công phổ biến như quét cổng, brute-force, khai thác lỗ hổng, tải mã độc, v.v... Đây là nguồn dữ liệu quý giá phục vụ cho việc phân tích, thống kê và đánh giá tình hình an ninh mạng.

Thứ hai, thông qua việc phân tích log tấn công, nhóm đã bước đầu xác định được các đặc trưng hành vi của tin tặc, bao gồm thời gian, tần suất, cổng dịch vụ, địa chỉ IP nguồn và phương thức khai thác. Việc này giúp hiểu rõ hơn xu hướng tấn công mạng hiện nay và đề xuất biện pháp phòng ngừa hiệu quả hơn trong thực tế.

Thứ ba, kết quả nghiên cứu cho thấy Honeypot là công cụ hữu ích và có tính ứng dụng cao trong việc giám sát an toàn thông tin, hỗ trợ nghiên cứu các hình thức tấn công mới và nâng cao khả năng phản ứng của hệ thống phòng thủ. Đây là nền tảng quan trọng để phát triển các mô hình phòng thủ chủ động trong tương lai.

5.2. Hạn chế của đề tài

Mặc dù đã đạt được những kết quả đáng khích lệ, đề tài vẫn còn tồn tại một số hạn chế nhất định như sau:

- Hệ thống mới chỉ dừng ở mức Honeypot tương tác thấp (Low/Medium Interaction), do đó chưa thể quan sát đầy đủ các hành vi chi tiết của kẻ tấn công sau khi xâm nhập thành công.

- Dữ liệu log thu thập được còn hạn chế về thời gian, quy mô và phạm vi thử nghiệm, chưa đủ lớn để phản ánh toàn diện bức tranh an ninh mạng thực tế.
- Việc phân tích và phân loại log chủ yếu dựa vào phương pháp thủ công, chưa ứng dụng mạnh mẽ các kỹ thuật tự động hóa hay học máy (Machine Learning) để tăng tốc độ và độ chính xác.
- Hệ thống hiện tại vẫn chưa tích hợp với các công cụ bảo mật khác như IDS/IPS hay SIEM, nên chưa đánh giá được khả năng phản ứng tự động khi phát hiện tấn công.

5.3. Hướng phát triển trong tương lai

Để nâng cao hiệu quả và mở rộng phạm vi ứng dụng của đề tài, nhóm nghiên cứu định hướng phát triển trong tương lai theo các hướng sau:

- Mở rộng và nâng cấp hệ thống Honeypot: Triển khai thêm các loại Honeypot tương tác cao và đa dạng dịch vụ (Web, SSH, IoT, Database...) để thu thập nhiều loại dữ liệu tấn công hơn, qua đó phân tích hành vi tin tặc ở mức độ sâu hơn.
- Ứng dụng trí tuệ nhân tạo và học máy: Xây dựng các mô hình phân tích log tự động, phát hiện bất thường, phân loại tấn công và dự đoán xu hướng tấn công trong tương lai. Điều này giúp tiết kiệm thời gian và tăng độ chính xác trong việc nhận diện nguy cơ.
- Tích hợp hệ thống với các nền tảng giám sát an ninh (SIEM, IDS/IPS): Nhằm tự động hóa quá trình cảnh báo, phản ứng và đưa ra biện pháp phòng thủ kịp thời trước các mối đe dọa thực tế.
- Mở rộng phạm vi nghiên cứu và thử nghiệm: Thực hiện triển khai honeypot trên nhiều môi trường mạng khác nhau, trong thời gian dài hơn để có được tập dữ liệu phong phú và khách quan hơn.

- Bảo đảm an toàn và pháp lý: Hoàn thiện cơ chế cách ly, lọc lưu lượng và chính sách vận hành để đảm bảo honeypot không bị lợi dụng cho mục đích tấn công, đồng thời tuân thủ các quy định về bảo mật và quyền riêng tư dữ liệu.

TÀI LIỆU THAM KHẢO

- [1] Tổng quan về honeypot: <https://whitehat.vn/threads/tong-quan-ve-honeypot.15118/>
- [2] Cài đặt Ubuntu: <https://ubuntu.com/download/desktop>
- [3] Nghiên cứu về Honeypot: <https://drive.google.com/file/d/113A9KMADT-yUg6kEyoeVABA1dSclA3To/view?usp=sharing>
- [4] Cài đặt Tpot: <https://github.com/telekom-security/tpotce>
- [5] Cài đặt Kali-linux: <https://www.kali.org/get-kali/#kali-installer-images>
- [6] Cài đặt Vmware:
<https://www.vmware.com/products/desktop-hypervisor/workstation-and-fusion>
- [7] Cài đặt Putty: <https://puttygen.com/download-putty>